

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Relationship	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	CHMCO 2.0 Level 2
3.1.1	N/A	Limit system access to authorized users, processes acting on behalf of authorized users, and devices (including other systems).	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10		ACL2 - 3.1.1
3.1.1	N/A	Limit system access to authorized users, processes acting on behalf of authorized users, and devices (including other systems).	Functional	Intersects With	Identification & Authentication for Organizational Users	IAC-02	Mechanisms exist to uniquely identify and centrally Authenticate, Authorize and Audit (AAA) organizational users and processes acting on behalf of organizational users.	5	updated in SCF release 2026.1	ACL2 - 3.1.1
3.1.1	N/A	Limit system access to authorized users, processes acting on behalf of authorized users, and devices (including other systems).	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	5		ACL2 - 3.1.1
3.1.1	N/A	Limit system access to authorized users, processes acting on behalf of authorized users, and devices (including other systems).	Functional	Intersects With	Automated System Account Management (Directory Services)	IAC-15.1	Automated mechanisms exist to support the management of system accounts (e.g., directory services).	5		ACL2 - 3.1.1
3.1.1	N/A	Limit system access to authorized users, processes acting on behalf of authorized users, and devices (including other systems).	Functional	Equal	Access Enforcement	IAC-20	Mechanisms exist to enforce Logical Access Control (LAC) permissions that conform to the principle of "least privilege."	10		ACL2 - 3.1.1
3.1.1	N/A	Limit system access to authorized users, processes acting on behalf of authorized users, and devices (including other systems).	Functional	Intersects With	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	8		ACL2 - 3.1.1
3.1.1	N/A	Limit system access to authorized users, processes acting on behalf of authorized users, and devices (including other systems).	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services	5		ACL2 - 3.1.1
3.1.1	N/A	Limit system access to authorized users, processes acting on behalf of authorized users, and devices (including other systems).	Functional	Intersects With	Contract Flow-Down Requirements	TPM-05.2	Mechanisms exist to ensure applicable security, compliance and resilience requirements are included in contracts that flow-down to applicable sub-contractors and suppliers.	5		ACL2 - 3.1.1
3.1.2	N/A	Limit system access to the types of transactions and functions that authorized users are permitted to execute.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	5		ACL2 - 3.1.2
3.1.2	N/A	Limit system access to the types of transactions and functions that authorized users are permitted to execute.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types;	5		ACL2 - 3.1.2
3.1.3	N/A	Control the flow of CUI in accordance with approved authorizations.	Functional	Intersects With	Media Access	DCH-02	Mechanisms exist to control and restrict access to digital and non-digital media to authorized individuals.	5		ACL2 - 3.1.3
3.1.3	N/A	Control the flow of CUI in accordance with approved authorizations.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	5		ACL2 - 3.1.3
3.1.3	N/A	Control the flow of CUI in accordance with approved authorizations.	Functional	Intersects With	Data Flow Enforcement - Access Control Lists (ACLs)	NET-04	Mechanisms exist to implement and govern Access Control Lists (ACLs) to provide data flow enforcement that explicitly restrict network traffic to only what is authorized.	5		ACL2 - 3.1.3
3.1.3	N/A	Control the flow of CUI in accordance with approved authorizations.	Functional	Intersects With	DNS & Content Filtering	NET-18	Mechanisms exist to force Internet-bound network traffic through a proxy device (e.g., Policy Enforcement Point (PEP)) for URL content filtering and DNS filtering to limit a user's ability to connect to dangerous or prohibited Internet sites.	5		ACL2 - 3.1.3
3.1.4	N/A	Separate the duties of individuals to reduce the risk of malevolent activity without collusion.	Functional	Equal	Separation of Duties (SoD)	HRS-11	Mechanisms exist to implement and maintain Separation of Duties (SoD) to prevent potential inappropriate activity without collusion.	10		ACL2 - 3.1.4
3.1.5	N/A	Employ the principle of least privilege, including for specific security functions and privileged accounts.	Functional	Intersects With	Privileged Account Management (PAM)	IAC-16	Mechanisms exist to restrict and control privileged access rights for users and Technology Assets, Applications and/or Services (TAAS).	5		ACL2 - 3.1.5
3.1.5	N/A	Employ the principle of least privilege, including for specific security functions and privileged accounts.	Functional	Equal	Privileged Account Inventories	IAC-16.1	Mechanisms exist to inventory all privileged accounts and validate that each person with elevated privileges is authorized by the appropriate level of organizational management.	10		ACL2 - 3.1.5
3.1.5	N/A	Employ the principle of least privilege, including for specific security functions and privileged accounts.	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	5		ACL2 - 3.1.5
3.1.5	N/A	Employ the principle of least privilege, including for specific security functions and privileged accounts.	Functional	Intersects With	Authorize Access to Security Functions	IAC-21.1	Mechanisms exist to limit access to security functions to explicitly-authorized privileged users.	5		ACL2 - 3.1.5
3.1.5	N/A	Employ the principle of least privilege, including for specific security functions and privileged accounts.	Functional	Intersects With	Management Approval For Privileged Accounts	IAC-21.3	Mechanisms exist to restrict the assignment of privileged accounts to management approved personnel and/or roles.	5		ACL2 - 3.1.5
3.1.6	N/A	Use non-privileged accounts or roles when accessing nonsecurity functions.	Functional	Equal	Non-Privileged Access for Non-Security Functions	IAC-21.2	Mechanisms exist to prohibit privileged users from using privileged accounts, while performing non-security functions.	10		ACL2 - 3.1.6
3.1.7	N/A	Prevent non-privileged users from executing privileged functions and capture the execution of such functions in audit logs.	Functional	Intersects With	Auditing Use of Privileged Functions	IAC-21.4	Mechanisms exist to audit the execution of privileged functions.	5		ACL2 - 3.1.7
3.1.7	N/A	Prevent non-privileged users from executing privileged functions and capture the execution of such functions in audit logs.	Functional	Equal	Prohibit Non-Privileged Users from Executing Privileged Functions	IAC-21.5	Mechanisms exist to prevent non-privileged users from executing privileged functions to include disabling, circumventing or altering implemented security safeguards / countermeasures.	10		ACL2 - 3.1.7
3.1.8	N/A	Limit unsuccessful login attempts.	Functional	Equal	Account Lockout	IAC-22	Mechanisms exist to enforce an organization-defined time period and automatically lock the account when the maximum number of unsuccessful attempts is exceeded.	10		ACL2 - 3.1.8
3.1.9	N/A	Provide privacy and security notices consistent with applicable CUI rules.	Functional	Equal	System Use Notification (Login Banner)	SEA-18	Mechanisms exist to utilize system use notification / login banners that display an approved system use notification message or banner before granting access to Technology Assets, Applications and/or Services (TAAS).	10		ACL2 - 3.1.9
3.1.9	N/A	Provide privacy and security notices consistent with applicable CUI rules.	Functional	Intersects With	Standardized Microsoft Windows Banner	SEA-18.1	Mechanisms exist to configure Microsoft Windows-based systems to display an approved login banner before granting access to the system.	5		ACL2 - 3.1.9
3.1.9	N/A	Provide privacy and security notices consistent with applicable CUI rules.	Functional	Intersects With	Truncated Banner	SEA-18.2	Mechanisms exist to utilize a truncated system use notification / login banner on systems not capable of displaying a login banner from a centralized directory services technology (e.g., Active Directory, Entra ID, etc.).	5		ACL2 - 3.1.9
3.1.10	N/A	Use session lock with pattern-hiding displays to prevent access and viewing of data after a period of inactivity.	Functional	Equal	Session Lock	IAC-24	Mechanisms exist to initiate a session lock after an organization-defined time period of inactivity, or upon receiving a request from a user and retain the session lock until the user reestablishes access using established identification and authentication methods.	10		ACL2 - 3.1.10
3.1.10	N/A	Use session lock with pattern-hiding displays to prevent access and viewing of data after a period of inactivity.	Functional	Intersects With	Pattern-Hiding Displays	IAC-24.1	Mechanisms exist to implement pattern-hiding displays to conceal information previously visible on the display during the session lock.	5		ACL2 - 3.1.10
3.1.11	N/A	Terminate (automatically) a user session after a defined condition.	Functional	Equal	Session Termination	IAC-25	Automated mechanisms exist to log out users, both locally on the network and for remote sessions, at the end of the session or after an organization-defined period of inactivity.	10		ACL2 - 3.1.11
3.1.12	N/A	Monitor and control remote access sessions.	Functional	Intersects With	Remote Access	NET-14	Mechanisms exist to define, control and review organization-approved, secure remote access methods.	5		ACL2 - 3.1.12
3.1.12	N/A	Monitor and control remote access sessions.	Functional	Intersects With	Automated Monitoring & Control	NET-14.1	Automated mechanisms exist to monitor and control remote access sessions.	5		ACL2 - 3.1.12
3.1.12	N/A	Monitor and control remote access sessions.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5		ACL2 - 3.1.12
3.1.13	N/A	Employ cryptographic mechanisms to protect the confidentiality of remote access sessions.	Functional	Equal	Protection of Confidentiality / Integrity Using Encryption	NET-14.2	Cryptographic mechanisms exist to protect the confidentiality and integrity of remote access sessions (e.g., VPN).	10		ACL2 - 3.1.13
3.1.14	N/A	Route remote access via managed access control points.	Functional	Equal	Managed Access Control Points	NET-14.3	Mechanisms exist to route all remote accesses through managed network access control points (e.g., VPN concentrator).	10		ACL2 - 3.1.14
3.1.15	N/A	Authorize remote execution of privileged commands and remote access to security-relevant information.	Functional	Equal	Remote Privileged Commands & Sensitive Data Access	NET-14.4	Mechanisms exist to restrict the execution of privileged commands and access to security-relevant information via remote access only for compelling operational needs.	10		ACL2 - 3.1.15
3.1.16	N/A	Authorize wireless access prior to allowing such connections.	Functional	Equal	Wireless Networking	NET-15	Mechanisms exist to control authorized wireless usage and monitor for unauthorized wireless access.	10		ACL2 - 3.1.16
3.1.17	N/A	Protect wireless access using authentication and encryption.	Functional	Intersects With	Authentication & Encryption	NET-15.1	Mechanisms exist to secure Wi-Fi (e.g., IEEE 802.11) and prevent unauthorized access by: (1) Authenticating devices trying to connect; and (2) Encrypting transmitted data.	5		ACL2 - 3.1.17
3.1.18	N/A	Control connection of mobile devices.	Functional	Subset Of	Centralized Management Of Mobile Devices	MDM-01	Mechanisms exist to implement and govern Mobile Device Management (MDM) controls.	10		ACL2 - 3.1.18
3.1.18	N/A	Control connection of mobile devices.	Functional	Equal	Access Control For Mobile Devices	MDM-02	Mechanisms exist to enforce access control requirements for the connection of mobile devices to organizational Technology Assets, Applications and/or Services (TAAS).	10		ACL2 - 3.1.18
3.1.18	N/A	Control connection of mobile devices.	Functional	Intersects With	Personally-Owned Mobile Devices	MDM-06	Mechanisms exist to restrict the connection of personally-owned, mobile devices to organizational Technology Assets, Applications and/or Services (TAAS).	5		ACL2 - 3.1.18
3.1.18	N/A	Control connection of mobile devices.	Functional	Intersects With	Organization-Owned Mobile Devices	MDM-07	Mechanisms exist to prohibit the installation of non-approved applications or approved applications not obtained through the organization-approved application store.	5		ACL2 - 3.1.18
3.1.19	N/A	Encrypt CUI on mobile devices and mobile computing platforms.	Functional	Equal	Full Device & Container-Based Encryption	MDM-03	Cryptographic mechanisms exist to protect the confidentiality and integrity of information on mobile devices through full-device or container encryption.	10		ACL2 - 3.1.19
3.1.20	N/A	Verify and control/limit connections to and use of external systems.	Functional	Equal	Technology Assets, Applications and/or	DCH-13	Mechanisms exist to govern how external parties, including Technology Assets, Applications and/or Services (TAAS), are used to securely store, process and transmit data.	10		ACL2 - 3.1.20
3.1.20	N/A	Verify and control/limit connections to and use of external systems.	Functional	Intersects With	Limits of Authorized Use	DCH-13.1	Mechanisms exist to prohibit external parties, including Technology Assets, Applications and/or Services (TAAS), from storing, processing and transmitting data unless authorized individuals first: (1) Verifying the implementation of required security, compliance and/or resilience controls; or	5		ACL2 - 3.1.20
3.1.20	N/A	Verify and control/limit connections to and use of external systems.	Functional	Intersects With	Ad-Hoc Transfers	DCH-17	Mechanisms exist to secure ad-hoc exchanges of large digital files with internal or external parties.	3		ACL2 - 3.1.20
3.1.21	N/A	Limit use of portable storage devices on external systems.	Functional	Equal	Portable Storage Devices	DCH-13.2	Mechanisms exist to restrict or prohibit the use of portable storage devices by users on external systems.	10		ACL2 - 3.1.21
3.1.22	N/A	Control CUI posted or processed on publicly accessible systems.	Functional	Intersects With	Cloud Services	CLD-01	Mechanisms exist to facilitate the implementation of cloud management controls to ensure cloud instances are secure and in-line with industry practices.	3		ACL2 - 3.1.22
3.1.22	N/A	Control CUI posted or processed on publicly accessible systems.	Functional	Intersects With	Cloud Security Architecture	CLD-02	Mechanisms exist to ensure the cloud security architecture supports the organization's technology strategy to securely design, configure and maintain cloud employments.	3		ACL2 - 3.1.22
3.1.22	N/A	Control CUI posted or processed on publicly accessible systems.	Functional	Intersects With	Multi-Tenant Environments	CLD-06	Mechanisms exist to ensure multi-tenant owned or managed assets (physical and virtual) are designed and governed such that provider and customer (tenant) user access is appropriately segmented from other tenant users.	5		ACL2 - 3.1.22
3.1.22	N/A	Control CUI posted or processed on publicly accessible systems.	Functional	Intersects With	Sensitive Data In Public Cloud Providers	CLD-10	Mechanisms exist to limit and manage the storage of sensitive and/or regulated data in public cloud providers.	5		ACL2 - 3.1.22
3.1.22	N/A	Control CUI posted or processed on publicly accessible systems.	Functional	Intersects With	Publicly Accessible Content	DCH-15	Mechanisms exist to control publicly-accessible content.	5		ACL2 - 3.1.22
3.1.22	N/A	Control CUI posted or processed on publicly accessible systems.	Functional	Intersects With	Human Resources Security Management	HRS-01	Mechanisms exist to facilitate the implementation of personnel security controls.	3		ACL2 - 3.1.22
3.1.22	N/A	Control CUI posted or processed on publicly accessible systems.	Functional	Intersects With	Terms of Employment	HRS-05	Mechanisms exist to require all employees and contractors to apply cybersecurity and data protection principles in their daily work to enable secure, compliant and	3		ACL2 - 3.1.22
3.1.22	N/A	Control CUI posted or processed on publicly accessible systems.	Functional	Intersects With	Rules of Behavior	HRS-05.1	Mechanisms exist to define acceptable and unacceptable rules of behavior for the use of technologies, including consequences for unacceptable behavior.	3		ACL2 - 3.1.22

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Reference	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	SCF Control	Notes	CHMCO 2.0 Level 2
3.1.22	N/A	Control CUI posted or processed on publicly accessible systems.	Functional	Intersects With	Social Media & Social Networking Restrictions	HRS-05.2	Mechanisms exist to define rules of behavior that contain explicit restrictions on the use of social media and networking sites, posting information on commercial websites and sharing account information.	3			ACL2.-3.1.22
3.1.22	N/A	Control CUI posted or processed on publicly accessible systems.	Functional	Intersects With	Web Security	WEB-01	Mechanisms exist to facilitate the implementation of an enterprise-wide web management policy, as well as associated standards, controls and procedures.	5			ACL2.-3.1.22
3.1.22	N/A	Control CUI posted or processed on publicly accessible systems.	Functional	Intersects With	Use of Demilitarized Zones (DMZ)	WEB-02	Mechanisms exist to utilize a Demilitarized Zone (DMZ) to restrict inbound traffic to authorized Technology Assets, Applications and/or Services (TAAS) on certain services, protocols and ports.	3			ACL2.-3.1.22
3.1.22	N/A	Control CUI posted or processed on publicly accessible systems.	Functional	Intersects With	Client-Facing Web Services	WEB-04	Mechanisms exist to deploy reasonably-expected security, compliance and resilience controls to protect the confidentiality and availability of client data that is stored, transmitted or processed by the Internet-based service.	5			ACL2.-3.1.22
3.2.1	N/A	Ensure that managers, systems administrators, and users of organizational systems are made aware of the security risks associated with their activities and of the applicable policies, standards, and procedures related to the security of those systems.	Functional	Intersects With	Formal Indoctrination	HRS-04.2	Mechanisms exist to formally educate authorized users on proper data handling practices for all the relevant types of data to which they have access.	8	updated in SCF release 2026.1		ATL2.-3.2.1
3.2.1	N/A	Ensure that managers, systems administrators, and users of organizational systems are made aware of the security risks associated with their activities and of the applicable policies, standards, and procedures related to the security of those systems.	Functional	Equal	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	10			ATL2.-3.2.1
3.2.2	N/A	Ensure that personnel are trained to carry out their assigned information security-related duties and responsibilities.	Functional	Intersects With	Formal Indoctrination	HRS-04.2	Mechanisms exist to formally educate authorized users on proper data handling practices for all the relevant types of data to which they have access.	8	updated in SCF release 2026.1		ATL2.-3.2.2
3.2.2	N/A	Ensure that personnel are trained to carry out their assigned information security-related duties and responsibilities.	Functional	Equal	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and (3) Annually thereafter.	10			ATL2.-3.2.2
3.2.3	N/A	Provide security awareness training on recognizing and reporting potential indicators of insider threat.	Functional	Intersects With	Cyber Threat Environment	SAT-03.6	Mechanisms exist to provide role-based security, compliance and resilience awareness training that is current and relevant to the cyber threats that users might encounter in day-to-day business operations.	8	updated in SCF release 2026.1		ATL2.-3.2.3
3.2.3	N/A	Provide security awareness training on recognizing and reporting potential indicators of insider threat.	Functional	Equal	Insider Threat Awareness	THR-05	Mechanisms exist to utilize security awareness training on recognizing and reporting potential indicators of insider threat.	10			ATL2.-3.2.3
3.3.1	N/A	Create and retain system audit logs and records to the extent needed to enable the monitoring, analysis, investigation, and reporting of unlawful or unauthorized system activity.	Functional	Equal	Centralized Collection of Security Event Logs	MON-02	Mechanisms exist to utilize a Security Incident Event Manager (SIEM), or similar automated tool, to support the centralized collection of security-related event logs.	10			AUL2.-3.3.1
3.3.1	N/A	Create and retain system audit logs and records to the extent needed to enable the monitoring, analysis, investigation, and reporting of unlawful or unauthorized system activity.	Functional	Equal	Event Log Retention	MON-10	Mechanisms exist to retain event logs for a time period consistent with records retention requirements to provide support for after-the-fact investigations of security incidents and to meet statutory, regulatory and contractual retention requirements.	10			AUL2.-3.3.1
3.3.2	N/A	Ensure that the actions of individual system users can be uniquely traced to those users, so they can be held accountable for their actions.	Functional	Equal	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	10			AUL2.-3.3.2
3.3.3	N/A	Review and update logged events.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	8	updated in SCF release 2026.1		AUL2.-3.3.3
3.3.3	N/A	Review and update logged events.	Functional	Intersects With	Reviews & Updates	CFG-02.1	Mechanisms exist to review and update baseline configurations: (1) At least annually; (2) When required due to so; or (3) As part of system component installations and upgrades.	8	updated in SCF release 2026.1		AUL2.-3.3.3
3.3.3	N/A	Review and update logged events.	Functional	Intersects With	Baseline Tailoring	CFG-02.9	Mechanisms exist to allow baseline controls to be specialized or customized by applying a defined set of tailoring actions that are specific to: (1) Mission / business functions; (2) Operational environment; (3) Specific threats or vulnerabilities; or (4) Other conditions or situations that could affect mission / business success.	8	updated in SCF release 2026.1		AUL2.-3.3.3
3.3.3	N/A	Review and update logged events.	Functional	Subset Of	Continuous Monitoring	MON-01	Mechanisms exist to facilitate the implementation of enterprise-wide monitoring controls.	10	updated in SCF release 2026.1		AUL2.-3.3.3
3.3.3	N/A	Review and update logged events.	Functional	Intersects With	Security Event Monitoring	MON-01.8	Mechanisms exist to review event logs on an ongoing basis and escalate incidents in accordance with established timelines and procedures.	8			AUL2.-3.3.3
3.3.3	N/A	Review and update logged events.	Functional	Intersects With	Analyze and Prioritize Monitoring Requirements	MON-01.16	Mechanisms exist to assess the organization's needs for monitoring and prioritize the monitoring of Technology Assets, Applications and/or Services (TAAS), based on TAAS criticality and the sensitivity of the data it stores, transmits and processes.	8	updated in SCF release 2026.1		AUL2.-3.3.3
3.3.3	N/A	Review and update logged events.	Functional	Intersects With	Centralized Collection of Security Event Logs	MON-02	Mechanisms exist to utilize a Security Incident Event Manager (SIEM), or similar automated tool, to support the centralized collection of security-related event logs.	5			AUL2.-3.3.3
3.3.4	N/A	Alert in the event of an audit logging process failure.	Functional	Equal	Response To Event Log Processing Failures	MON-05	Mechanisms exist to alert appropriate personnel in the event of a log processing failure and take actions to remedy the disruption.	10			AUL2.-3.3.4
3.3.5	N/A	Correlate audit record review, analysis, and reporting processes for investigation and response to indications of unlawful, unauthorized, suspicious, or unusual activity.	Functional	Intersects With	Centralized Collection of Security Event Logs	MON-02	Mechanisms exist to utilize a Security Incident Event Manager (SIEM), or similar automated tool, to support the centralized collection of security-related event logs.	5			AUL2.-3.3.5
3.3.5	N/A	Correlate audit record review, analysis, and reporting processes for investigation and response to indications of unlawful, unauthorized, suspicious, or unusual activity.	Functional	Equal	Correlate Monitoring Information	MON-02.1	Automated mechanisms exist to correlate both technical and non-technical information from across the enterprise by a Security Incident Event Manager (SIEM) or similar automated tool, to enhance organization-wide situational awareness.	10			AUL2.-3.3.5
3.3.6	N/A	Provide audit record reduction and report generation to support on-demand analysis and reporting.	Functional	Equal	Centralized Collection of Security Event Logs	MON-02	Mechanisms exist to utilize a Security Incident Event Manager (SIEM), or similar automated tool, to support the centralized collection of security-related event logs.	10			AUL2.-3.3.6
3.3.6	N/A	Provide audit record reduction and report generation to support on-demand analysis and reporting.	Functional	Intersects With	Monitoring Reporting	MON-06	Mechanisms exist to provide an event log report generation capability to aid in monitoring and assessing anomalous activities.	5			AUL2.-3.3.6
3.3.7	N/A	Provide a system capability that compares and synchronizes internal system clocks with an authoritative source to generate time stamps for audit records.	Functional	Equal	Synchronization With Authoritative Time Source	MON-07.1	Mechanisms exist to synchronize internal system clocks with an authoritative time source.	10			AUL2.-3.3.7
3.3.7	N/A	Provide a system capability that compares and synchronizes internal system clocks with an authoritative source to generate time stamps for audit records.	Functional	Intersects With	Clock Synchronization	SEA-20	Mechanisms exist to utilize time-synchronization technology to synchronize all critical system clocks.	5			AUL2.-3.3.7
3.3.8	N/A	Protect audit information and audit logging tools from unauthorized access, modification, and deletion.	Functional	Intersects With	Centralized Collection of Security Event Logs	MON-02	Mechanisms exist to utilize a Security Incident Event Manager (SIEM), or similar automated tool, to support the centralized collection of security-related event logs.	5			AUL2.-3.3.8
3.3.8	N/A	Protect audit information and audit logging tools from unauthorized access, modification, and deletion.	Functional	Intersects With	Sensitive Event Log Information	MON-03.1	Mechanisms exist to protect sensitive and/or regulated data contained in log files.	5			AUL2.-3.3.8
3.3.8	N/A	Protect audit information and audit logging tools from unauthorized access, modification, and deletion.	Functional	Equal	Protection of Event Logs	MON-08	Mechanisms exist to protect event logs and audit tools from unauthorized access, modification and deletion.	10			AUL2.-3.3.8
3.3.9	N/A	Limit management of audit logging functionality to a subset of privileged users.	Functional	Intersects With	Centralized Collection of Security Event Logs	MON-02	Mechanisms exist to utilize a Security Incident Event Manager (SIEM), or similar automated tool, to support the centralized collection of security-related event logs.	5			AUL2.-3.3.9
3.3.9	N/A	Limit management of audit logging functionality to a subset of privileged users.	Functional	Equal	Access by Subset of Privileged Users	MON-08.2	Mechanisms exist to restrict access to the management of event logs to privileged users with a specific business need.	10			AUL2.-3.3.9
3.4.1	N/A	Establish and maintain baseline configurations and inventories of organizational systems (including hardware, software, firmware, and documentation) throughout the respective system development life cycles.	Functional	Subset Of	Asset Governance	AST-01	Mechanisms exist to facilitate an IT Asset Management (ITAM) program to implement and manage asset management controls.	10			CHL2.-3.4.1
3.4.1	N/A	Establish and maintain baseline configurations and inventories of organizational systems (including hardware, software, firmware, and documentation) throughout the respective system development life cycles.	Functional	Intersects With	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: (1) Accurately reflects the current TAASD in use; (2) Identifies authorized software products, including business justification details; (3) Is at the level of granularity deemed necessary for tracking and reporting; (4) Includes organization-defined information deemed necessary to achieve effective property accountability; and (5) Is available for review and audit by designated organizational personnel.	5			CHL2.-3.4.1
3.4.1	N/A	Establish and maintain baseline configurations and inventories of organizational systems (including hardware, software, firmware, and documentation) throughout the respective system development life cycles.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5			CHL2.-3.4.1
3.4.2	N/A	Establish and enforce security configuration settings for information technology products employed in organizational systems.	Functional	Equal	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	10			CHL2.-3.4.2
3.4.3	N/A	Track, review, approve or disapprove, and log changes to organizational systems.	Functional	Subset Of	Change Management Program	CHG-01	Mechanisms exist to facilitate the implementation of a change management program.	10			CHL2.-3.4.3
3.4.3	N/A	Track, review, approve or disapprove, and log changes to organizational systems.	Functional	Equal	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10			CHL2.-3.4.3
3.4.4	N/A	Analyze the security impact of changes prior to implementation.	Functional	Equal	Security Impact Analysis for Changes	CHG-03	Mechanisms exist to analyze proposed changes for potential security impacts, prior to the implementation of the change.	10			CHL2.-3.4.4
3.4.5	N/A	Define, document, approve, and enforce physical and logical access restrictions associated with changes to organizational systems.	Functional	Equal	Access Restriction For Change	CHG-04	Mechanisms exist to enforce configuration restrictions in an effort to restrict the ability of users to conduct unauthorized changes.	10			CHL2.-3.4.5
3.4.5	N/A	Define, document, approve, and enforce physical and logical access restrictions associated with changes to organizational systems.	Functional	Intersects With	Separation of Development, Testing and Operational Environments	TOA-08	Mechanisms exist to manage separate development, testing and operational environments to reduce the risks of unauthorized access or changes to the operational environment and to ensure no impact to production Technology Assets, Applications and/or Services (TAAS).	5			CHL2.-3.4.5
3.4.6	N/A	Employ the principle of least functionality by configuring organizational systems to provide only essential capabilities.	Functional	Equal	Least Functionality	CFG-03	Mechanisms exist to configure systems to provide only essential capabilities by specifically prohibiting or restricting the use of ports, protocols, and/or services.	10			CHL2.-3.4.6
3.4.7	N/A	Restrict, disable, or prevent the use of nonessential programs, functions, ports, protocols, and services.	Functional	Equal	Periodic Review	CFG-03.1	Mechanisms exist to periodically review system configurations to identify and disable unnecessary and/or non-secure functions, ports, protocols and services.	10			CHL2.-3.4.7
3.4.7	N/A	Restrict, disable, or prevent the use of nonessential programs, functions, ports, protocols, and services.	Functional	Intersects With	Prevent Unauthorized Software Execution	CFG-03.2	Mechanisms exist to configure systems to prevent the execution of unauthorized software programs.	5			CHL2.-3.4.7
3.4.8	N/A	Apply deny-by-execution (blacklisting) policy to prevent the use of unauthorized software or deny-all, permit-by-execution (whitelisting) policy to allow the execution of authorized software.	Functional	Equal	Explicitly Allow / Deny Applications	CFG-03.3	Mechanisms exist to explicitly allow (allowlist / whitelist) and/or block (denylist / blacklist) applications that are authorized to execute on systems.	10			CHL2.-3.4.8
3.4.9	N/A	Control and monitor user-installed software.	Functional	Equal	User-Installed Software	CFG-05	Mechanisms exist to restrict the ability of non-privileged users to install unauthorized software.	10			CHL2.-3.4.9

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Reference	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	CHMNC 2.0 Level 2
3.4.9	N/A	Control and monitor user-installed software.	Functional	Intersects With	Prohibit Installation Without Privileged Status	END-03	Automated mechanisms exist to prohibit software installations without explicitly assigned privileged status.	5		CHML2-3.4.9
3.5.1	N/A	Identify system users, processes acting on behalf of users, and devices.	Functional	Equal	Identification & Authentication for Organizational Users	IAC-02	Mechanisms exist to uniquely identify and centrally Authenticate, Authorize and Audit (AAA) organizational users and processes acting on behalf of organizational users.	10		IAL2-3.5.1
3.5.1	N/A	Identify system users, processes acting on behalf of users, and devices.	Functional	Intersects With	Identification & Authentication for Devices	IAC-04	Mechanisms exist to uniquely identify and centrally Authenticate, Authorize and Audit (AAA) devices before establishing a connection using bidirectional authentication that is cryptographically-based and replay resistant.	5		IAL2-3.5.1
3.5.1	N/A	Identify system users, processes acting on behalf of users, and devices.	Functional	Intersects With	Automated System Account Management (Directory Services)	IAC-15.1	Automated mechanisms exist to support the management of system accounts (e.g., directory services).	8		IAL2-3.5.1
3.5.2	N/A	Authenticate (or verify) the identities of users, processes, or devices, as a prerequisite to allowing access to organizational systems.	Functional	Intersects With	Identification & Authentication for Organizational Users	IAC-02	Mechanisms exist to uniquely identify and centrally Authenticate, Authorize and Audit (AAA) organizational users and processes acting on behalf of organizational users.	5		IAL2-3.5.2
3.5.2	N/A	Authenticate (or verify) the identities of users, processes, or devices, as a prerequisite to allowing access to organizational systems.	Functional	Intersects With	Identification & Authentication for Devices	IAC-04	Mechanisms exist to uniquely identify and centrally Authenticate, Authorize and Audit (AAA) devices before establishing a connection using bidirectional authentication that is cryptographically-based and replay resistant.	5		IAL2-3.5.2
3.5.2	N/A	Authenticate (or verify) the identities of users, processes, or devices, as a prerequisite to allowing access to organizational systems.	Functional	Intersects With	Automated System Account Management (Directory Services)	IAC-15.1	Automated mechanisms exist to support the management of system accounts (e.g., directory services).	5		IAL2-3.5.2
3.5.3	N/A	Use multifactor authentication for local and network access to privileged accounts and for network access to non-privileged accounts.	Functional	Intersects With	Multi-Factor Authentication (MFA)	IAC-06	Automated mechanisms exist to enforce Multi-Factor Authentication (MFA) for: (1) Remote network access; (2) Third-party Technology Assets, Applications and/or Services (TAAS); and/ or (3) Non-console access to critical TAAS that store, transmit and/or process sensitive and/or regulated data.	5		IAL2-3.5.3
3.5.3	N/A	Use multifactor authentication for local and network access to privileged accounts and for network access to non-privileged accounts.	Functional	Intersects With	Network Access to Privileged Accounts	IAC-06.1	Mechanisms exist to utilize Multi-Factor Authentication (MFA) to authenticate network access for privileged accounts.	5		IAL2-3.5.3
3.5.3	N/A	Use multifactor authentication for local and network access to privileged accounts and for network access to non-privileged accounts.	Functional	Intersects With	Network Access to Non-Privileged Accounts	IAC-06.2	Mechanisms exist to utilize Multi-Factor Authentication (MFA) to authenticate network access for non-privileged accounts.	5		IAL2-3.5.3
3.5.3	N/A	Use multifactor authentication for local and network access to privileged accounts and for network access to non-privileged accounts.	Functional	Intersects With	Local Access to Privileged Accounts	IAC-06.3	Mechanisms exist to utilize Multi-Factor Authentication (MFA) to authenticate local access for privileged accounts.	5		IAL2-3.5.3
3.5.4	N/A	Employ replay-resistant authentication mechanisms for network access to privileged and nonprivileged accounts.	Functional	Equal	Replay-Resistant Authentication	IAC-02.2	Automated mechanisms exist to employ replay-resistant authentication.	10		IAL2-3.5.4
3.5.5	N/A	Prevent reuse of identifiers for a defined period.	Functional	Equal	Identifier Management (User Names)	IAC-09	Mechanisms exist to govern naming standards for usernames and Technology Assets, Applications and/or Services (TAAS).	10		IAL2-3.5.5
3.5.6	N/A	Disable identifiers after a defined period of inactivity.	Functional	Intersects With	Disable Inactive Accounts	IAC-15.3	Automated mechanisms exist to disable inactive accounts after an organization-defined time period.	5		IAL2-3.5.6
3.5.7	N/A	Enforce a minimum password complexity and change of characters when new passwords are created.	Functional	Equal	Password-Based Authentication	IAC-10.1	Mechanisms exist to enforce complexity, length and lifespan considerations to ensure strong criteria for password-based authentication.	10		IAL2-3.5.7
3.5.8	N/A	Prohibit password reuse for a specified number of generations.	Functional	Subset Of	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	10		IAL2-3.5.8
3.5.9	N/A	Allow temporary password use for system logons with an immediate change to a permanent password.	Functional	Subset Of	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	10		IAL2-3.5.9
3.5.10	N/A	Store and transmit only cryptographically-protected passwords.	Functional	Intersects With	Protection of Authenticators	IAC-10.5	Mechanisms exist to protect authenticators commensurate with the sensitivity of the information to which use of the authenticator permits access.	5		IAL2-3.5.10
3.5.11	N/A	Obscure feedback of authentication information.	Functional	Equal	Authenticator Feedback	IAC-11	Mechanisms exist to obscure the feedback of authentication information during the authentication process to protect the information from possible exploitation/use by unauthorized individuals.	10		IAL2-3.5.11
3.6.1	N/A	Establish an operational incident-handling capability for organizational systems that includes preparation, detection, analysis, containment, recovery, and user response activities.	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10		IRL2-3.6.1
3.6.1	N/A	Establish an operational incident-handling capability for organizational systems that includes preparation, detection, analysis, containment, recovery, and user response activities.	Functional	Intersects With	Incident Response Training	IRO-05	Mechanisms exist to train personnel in their incident response roles and responsibilities.	5		IRL2-3.6.1
3.6.2	N/A	Track, document, and report incidents to designated officials and/or authorities both internal and external to the organization.	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10		IRL2-3.6.2
3.6.3	N/A	Test the organizational incident response capability.	Functional	Equal	Incident Response Testing	IRO-06	Mechanisms exist to formally test incident response capabilities through realistic exercises to determine the operational effectiveness of those capabilities.	10		IRL2-3.6.3
3.7.1	N/A	Perform maintenance on organizational systems.	Functional	Subset Of	Controlled Maintenance	MNT-02	Mechanisms exist to conduct controlled maintenance activities throughout the lifecycle of the Technology Asset, Application and/or Service (TAAS).	10		MAL2-3.7.1
3.7.2	N/A	Provide controls on the tools, techniques, mechanisms, and personnel used to conduct system maintenance.	Functional	Subset Of	Maintenance Tools	MNT-04	Mechanisms exist to control and monitor the use of system maintenance tools.	10		MAL2-3.7.2
3.7.3	N/A	Ensure equipment removed for off-site maintenance is sanitized of any CUI.	Functional	Subset Of	System Media Sanitization	DCH-09	Mechanisms exist to sanitize system media with the strength and integrity commensurate with the classification or sensitivity of the information prior to disposal, release out of organizational control or release for reuse.	10		MAL2-3.7.3
3.7.4	N/A	Check media containing diagnostic and test programs for malicious code before the media are used in organizational systems.	Functional	Equal	Inspect Media	MNT-04.2	Mechanisms exist to check media containing diagnostic and test programs for malicious code before the media are used.	10		MAL2-3.7.4
3.7.5	N/A	Require multifactor authentication to establish nonlocal maintenance sessions via external network connections and terminate such connections when nonlocal maintenance is complete.	Functional	Intersects With	Multi-Factor Authentication (MFA)	IAC-06	Automated mechanisms exist to enforce Multi-Factor Authentication (MFA) for: (1) Remote network access; (2) Third-party Technology Assets, Applications and/or Services (TAAS); and/ or (3) Non-console access to critical TAAS that store, transmit and/or process sensitive and/or regulated data.	8	updated in SCF release 2026.1	MAL2-3.7.5
3.7.5	N/A	Require multifactor authentication to establish nonlocal maintenance sessions via external network connections and terminate such connections when nonlocal maintenance is complete.	Functional	Subset Of	Remote Maintenance	MNT-05	Mechanisms exist to authorize, monitor and control remote, non-local maintenance and diagnostic activities.	10	updated in SCF release 2026.1	MAL2-3.7.5
3.7.5	N/A	Require multifactor authentication to establish nonlocal maintenance sessions via external network connections and terminate such connections when nonlocal maintenance is complete.	Functional	Intersects With	Remote Maintenance Disconnect Verification	MNT-05.4	Mechanisms exist to provide remote disconnect verification to ensure remote, non-local maintenance and diagnostic sessions are properly terminated.	3	updated in SCF release 2026.1	MAL2-3.7.5
3.7.6	N/A	Supervise the maintenance activities of maintenance personnel without required access authorization.	Functional	Intersects With	Authorized Maintenance Personnel	MNT-06	Mechanisms exist to maintain a current list of authorized maintenance organizations or personnel.	5		MAL2-3.7.6
3.7.6	N/A	Supervise the maintenance activities of maintenance personnel without required access authorization.	Functional	Intersects With	Maintenance Personnel Without Appropriate Access	MNT-06.1	Mechanisms exist to ensure the risks associated with maintenance personnel who do not have appropriate access authorizations, clearances or formal access approvals are appropriately mitigated.	5	updated in SCF release 2026.1	MAL2-3.7.6
3.7.6	N/A	Supervise the maintenance activities of maintenance personnel without required access authorization.	Functional	Intersects With	Non-System Related Maintenance	MNT-06.2	Mechanisms exist to ensure that non-recorded personnel performing non-IT maintenance activities in the physical proximity of systems have required access authorizations.	5	updated in SCF release 2026.1	MAL2-3.7.6
3.8.1	N/A	Protect (i.e., physically control and securely store) system media containing CUI, both paper and digital.	Functional	Subset Of	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	10		MPL2-3.8.1
3.8.1	N/A	Protect (i.e., physically control and securely store) system media containing CUI, both paper and digital.	Functional	Intersects With	Media Storage	DCH-06	Mechanisms exist to: (1) Physically control and securely store digital and non-digital media within controlled areas using organization-defined security measures; and (2) Protect system media until the media are destroyed or sanitized using approved equipment, techniques and procedures.	5		MPL2-3.8.1
3.8.2	N/A	Limit access to CUI on system media to authorized users.	Functional	Equal	Media Access	DCH-03	Mechanisms exist to control and restrict access to digital and non-digital media to authorized individuals.	10		MPL2-3.8.2
3.8.3	N/A	Sanitize or destroy system media containing CUI before disposal or release for reuse.	Functional	Subset Of	Asset Governance	AST-01	Mechanisms exist to facilitate an IT Asset Management (ITAM) program to implement and manage asset management controls.	10		MPL2-3.8.3
3.8.3	N/A	Sanitize or destroy system media containing CUI before disposal or release for reuse.	Functional	Intersects With	Secure Disposal, Destruction or Re-Use of Equipment	AST-09	Mechanisms exist to securely dispose of, destroy or repurpose system components using organization-defined techniques and methods to prevent information being recovered from these components.	8		MPL2-3.8.3
3.8.3	N/A	Sanitize or destroy system media containing CUI before disposal or release for reuse.	Functional	Intersects With	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	3		MPL2-3.8.3
3.8.3	N/A	Sanitize or destroy system media containing CUI before disposal or release for reuse.	Functional	Equal	Physical Media Disposal	DCH-08	Mechanisms exist to securely dispose of media when it is no longer required, using formal procedures.	10		MPL2-3.8.3
3.8.3	N/A	Sanitize or destroy system media containing CUI before disposal or release for reuse.	Functional	Intersects With	System Media Sanitization	DCH-09	Mechanisms exist to sanitize system media with the strength and integrity commensurate with the classification or sensitivity of the information prior to disposal, release out of organizational control or release for reuse.	8		MPL2-3.8.3
3.8.4	N/A	Mark media with necessary CUI markings and distribution limitations.	Functional	Equal	Media Marking	DCH-04	Mechanisms exist to mark media in accordance with data protection requirements so that personnel are alerted to distribution limitations, handling caveats and applicable security requirements.	10		MPL2-3.8.4
3.8.5	N/A	Control access to media containing CUI and maintain accountability for media during transport outside of controlled areas.	Functional	Equal	Media Transportation	DCH-07	Mechanisms exist to protect and control digital and non-digital media during transport outside of controlled areas using appropriate security measures.	10		MPL2-3.8.5
3.8.6	N/A	Implement cryptographic mechanisms to protect the confidentiality of CUI stored on digital media during transport unless otherwise protected by alternative physical safeguards.	Functional	Intersects With	Alternate Physical Protection	CRY-01.1	Cryptographic mechanisms exist to prevent unauthorized disclosure of information as an alternative to physical safeguards.	5	updated in SCF release 2026.1	MPL2-3.8.6
3.8.6	N/A	Implement cryptographic mechanisms to protect the confidentiality of CUI stored on digital media during transport unless otherwise protected by alternative physical safeguards.	Functional	Intersects With	Encrypting Data At Rest	CRY-05	Cryptographic mechanisms exist to prevent unauthorized disclosure of data at rest.	8		MPL2-3.8.6
3.8.7	N/A	Control the use of removable media on system components.	Functional	Equal	Media Use	DCH-10	Mechanisms exist to restrict the use of types of digital media on systems or system components.	10		MPL2-3.8.7
3.8.8	N/A	Prohibit the use of portable storage devices when such devices have no identifiable owner.	Functional	Equal	Prohibit Use Without Owner	DCH-10.2	Mechanisms exist to prohibit the use of portable storage devices in organizational systems when such devices have no identifiable owner.	10		MPL2-3.8.8

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Reference	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	CHMHC 2.0 Level 2
3.8.9	N/A	Protect the confidentiality of backup CUI at storage locations.	Functional	Intersects With	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to satisfy Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	5		MPL2-3.8.9
3.8.9	N/A	Protect the confidentiality of backup CUI at storage locations.	Functional	Intersects With	Cryptographic Protection	BCD-11.4	Cryptographic mechanisms exist to prevent the unauthorized disclosure and/or modification of backup information.	8		MPL2-3.8.9
3.9.1	N/A	Screen individuals prior to authorizing access to organizational systems containing CUI.	Functional	Subset Of	Personnel Screening	HRS-04	Mechanisms exist to manage personnel security risk by screening individuals prior to authorizing access.	10		PSL2-3.9.1
3.9.1	N/A	Screen individuals prior to authorizing access to organizational systems containing CUI.	Functional	Intersects With	Rules With Special Protection Measures	HRS-04.1	Mechanisms exist to ensure that individuals accessing a system that stores, transmits or processes information requiring special protection satisfy organization defined personnel screening criteria.	5	updated in SCF release 2026.1	PSL2-3.9.1
3.9.2	N/A	Ensure that organizational systems containing CUI are protected during and after personnel actions such as terminations and transfers.	Functional	Intersects With	Onboarding, Transferring & Offboarding Personnel	HRS-01.1	Mechanisms exist to proactively govern the following personnel management actions: (1) Onboarding new personnel (e.g., new hires); (2) Transferring personnel into new roles within the organization; and (3) Offboarding personnel (e.g., termination of employment).	8	updated in SCF release 2026.1	PSL2-3.9.2
3.9.2	N/A	Ensure that organizational systems containing CUI are protected during and after personnel actions such as terminations and transfers.	Functional	Intersects With	Personnel Transfer	HRS-08	Mechanisms exist to adjust logical and physical access authorizations to Technology Assets, Applications and/or Services (TAAS) and facilities upon personnel reassignment or transfer, in a timely manner.	8		PSL2-3.9.2
3.9.2	N/A	Ensure that organizational systems containing CUI are protected during and after personnel actions such as terminations and transfers.	Functional	Intersects With	Personnel Termination	HRS-09	Mechanisms exist to govern the termination of individual employment.	8		PSL2-3.9.2
3.10.1	N/A	Limit physical access to organizational systems, equipment, and the respective operating environments to authorized individuals.	Functional	Equal	Physical Access Authorizations	PES-02	Physical access control mechanisms exist to maintain a current list of personnel with authorized access to organizational facilities (except for those areas within the facility officially designated as publicly accessible).	10		PEL2-3.10.1
3.10.1	N/A	Limit physical access to organizational systems, equipment, and the respective operating environments to authorized individuals.	Functional	Intersects With	Role-Based Physical Access	PES-02.1	Physical access control mechanisms exist to authorize physical access to facilities based on the position or role of the individual.	5	updated in SCF release 2026.1	PEL2-3.10.1
3.10.1	N/A	Limit physical access to organizational systems, equipment, and the respective operating environments to authorized individuals.	Functional	Intersects With	Access To Critical Systems	PES-03.4	Physical access control mechanisms exist to enforce physical access to critical systems or sensitive and/or regulated data, in addition to the physical access controls for the facility.	5	updated in SCF release 2026.1	PEL2-3.10.1
3.10.1	N/A	Limit physical access to organizational systems, equipment, and the respective operating environments to authorized individuals.	Functional	Intersects With	Equipment Siting & Protection	PES-12	Physical security mechanisms exist to locate system components within the facility to minimize potential damage from physical and environmental hazards and to minimize the opportunity for unauthorized access.	5		PEL2-3.10.1
3.10.1	N/A	Limit physical access to organizational systems, equipment, and the respective operating environments to authorized individuals.	Functional	Intersects With	Transmission Medium Security	PES-12.1	Physical security mechanisms exist to protect power and telecommunications cabling carrying data or supporting information services from interception, interference or damage.	5		PEL2-3.10.1
3.10.1	N/A	Limit physical access to organizational systems, equipment, and the respective operating environments to authorized individuals.	Functional	Intersects With	Access Control for Output Devices	PES-12.2	Physical security mechanisms exist to restrict access to printers and other system output devices to prevent unauthorized individuals from obtaining the output.	5		PEL2-3.10.1
3.10.2	N/A	Protect and monitor the physical facility and support infrastructure for organizational systems.	Functional	Subset Of	Physical & Environmental Protections	PES-01	Mechanisms exist to facilitate the operation of physical and environmental protection controls.	10		PEL2-3.10.2
3.10.2	N/A	Protect and monitor the physical facility and support infrastructure for organizational systems.	Functional	Intersects With	Monitoring Physical Access	PES-05	Physical access control mechanisms exist to monitor for, detect and respond to physical security incidents.	5		PEL2-3.10.2
3.10.2	N/A	Protect and monitor the physical facility and support infrastructure for organizational systems.	Functional	Intersects With	Intrusion Alarms / Surveillance Equipment	PES-05.1	Physical access control mechanisms exist to monitor physical intrusion alarms and surveillance equipment.	5		PEL2-3.10.2
3.10.2	N/A	Protect and monitor the physical facility and support infrastructure for organizational systems.	Functional	Intersects With	Monitoring Physical Access To Critical Systems	PES-05.2	Facility security mechanisms exist to monitor physical access to critical systems or sensitive and/or regulated data, in addition to the physical access monitoring of the facility.	5		PEL2-3.10.2
3.10.3	N/A	Escort visitors and monitor visitor activity.	Functional	Subset Of	Physical Access Control	PES-03	Physical access control mechanisms exist to enforce physical access authorizations for all physical access points (including designated entry/exit points) to facilities (excluding those areas within the facility officially designated as publicly accessible).	10	updated in SCF release 2026.1	PEL2-3.10.3
3.10.3	N/A	Escort visitors and monitor visitor activity.	Functional	Intersects With	Visitor Control	PES-06	Physical access control mechanisms exist to identify, authorize and monitor visitors before allowing access to the facility (other than areas designated as publicly accessible).	5		PEL2-3.10.3
3.10.3	N/A	Escort visitors and monitor visitor activity.	Functional	Intersects With	Distinguishing Visitors from On-Site Personnel	PES-06.1	Physical access control mechanisms exist to easily distinguish between onsite personnel and visitors, especially in areas where sensitive and/or regulated data is accessible.	5	updated in SCF release 2026.1	PEL2-3.10.3
3.10.3	N/A	Escort visitors and monitor visitor activity.	Functional	Intersects With	Restrict Unescorted Access	PES-06.3	Physical access control mechanisms exist to restrict unescorted access to facilities with required security clearances, formal access authorizations and validate the need for access.	5		PEL2-3.10.3
3.10.4	N/A	Maintain audit logs of physical access.	Functional	Equal	Physical Access Logs	PES-03.3	Physical access control mechanisms generate a log entry for each access attempt through controlled ingress and egress points.	10		PEL2-3.10.4
3.10.5	N/A	Control and manage physical access devices.	Functional	Equal	Physical Access Control	PES-03	Physical access control mechanisms exist to enforce physical access authorizations for all physical access points (including designated entry/exit points) to facilities (excluding those areas within the facility officially designated as publicly accessible).	10		PEL2-3.10.5
3.10.5	N/A	Control and manage physical access devices.	Functional	Intersects With	Physical Security of Offices, Rooms & Facilities	PES-04	Mechanisms exist to identify systems, equipment and respective operating environments that require limited physical access so that appropriate physical access controls are designed and implemented for offices, rooms and facilities.	5		PEL2-3.10.5
3.10.6	N/A	Enforce safeguarding measures for CUI at alternate work sites.	Functional	Intersects With	Sensitive / Regulated Data Protection	DCH-01.2	Mechanisms exist to protect sensitive and/or regulated data wherever it is processed and/or stored.	8	updated in SCF release 2026.1	PEL2-3.10.6
3.10.6	N/A	Enforce safeguarding measures for CUI at alternate work sites.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5		PEL2-3.10.6
3.10.6	N/A	Enforce safeguarding measures for CUI at alternate work sites.	Functional	Subset Of	Alternate Work Site	PES-11	Physical security mechanisms exist to utilize appropriate management, operational and technical controls at alternate work sites.	10		PEL2-3.10.6
3.11.1	N/A	Periodically assess the risk to organizational operations (including mission, functions, image, or reputation), organizational assets, and individuals, resulting from the operation of organizational systems and the associated processing, storage, or transmission of CUI.	Functional	Equal	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	10		RAL2-3.11.1
3.11.2	N/A	Scan for vulnerabilities in organizational systems and applications periodically and when new vulnerabilities affecting those systems and applications are identified.	Functional	Subset Of	Vulnerability Scanning	VPM-06	Mechanisms exist to detect vulnerabilities and configuration errors by routine vulnerability scanning of systems and applications.	10		RAL2-3.11.2
3.11.2	N/A	Scan for vulnerabilities in organizational systems and applications periodically and when new vulnerabilities affecting those systems and applications are identified.	Functional	Intersects With	Privileged Access	VPM-06.3	Mechanisms exist to implement privileged access authorization for selected vulnerability scanning activities.	5		RAL2-3.11.2
3.11.3	N/A	Remediate vulnerabilities in accordance with risk assessments.	Functional	Intersects With	Risk Remediation	RSK-06	Mechanisms exist to remediate risks to an acceptable level.	8		RAL2-3.11.3
3.11.3	N/A	Remediate vulnerabilities in accordance with risk assessments.	Functional	Intersects With	Continuous Vulnerability Remediation Activities	VPM-04	Mechanisms exist to address new threats and vulnerabilities on an ongoing basis and ensure assets are protected against known attacks.	8	updated in SCF release 2026.1	RAL2-3.11.3
3.11.3	N/A	Remediate vulnerabilities in accordance with risk assessments.	Functional	Intersects With	Software & Firmware Patching	VPM-05	Mechanisms exist to conduct software patching for all deployed Technology Assets, Applications and/or Services (TAAS), including firmware.	8		RAL2-3.11.3
3.12.1	N/A	Periodically assess the security controls in organizational systems to determine if the controls are effective in their application.	Functional	Equal	Security, Compliance & Resilience Controls Oversight	CPL-02	Mechanisms exist to provide a security, compliance and resilience controls oversight function that reports to the organization's executive leadership.	10		CAL2-3.12.1
3.12.1	N/A	Periodically assess the security controls in organizational systems to determine if the controls are effective in their application.	Functional	Intersects With	Internal Audit Function	CPL-02.1	Mechanisms exist to implement an internal audit function that is capable of providing senior organization management with insights into the appropriateness of the organization's technology and information governance processes.	5		CAL2-3.12.1
3.12.1	N/A	Periodically assess the security controls in organizational systems to determine if the controls are effective in their application.	Functional	Intersects With	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	5		CAL2-3.12.1
3.12.1	N/A	Periodically assess the security controls in organizational systems to determine if the controls are effective in their application.	Functional	Intersects With	Assessments	IAO-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to determine the extent to which the controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting expected requirements.	5		CAL2-3.12.1
3.12.2	N/A	Develop and implement plans of action designed to correct deficiencies and reduce or eliminate vulnerabilities in organizational systems.	Functional	Equal	Capabilities Deficiency Tracking	IAO-05	Mechanisms exist to govern identified deficiencies (e.g., Plan of Action and Milestones (POA&M) or similar methodology) that formally documents, at a minimum: (1) Deficiency tracking number;	10		CAL2-3.12.2
3.12.3	N/A	Monitor security controls on an ongoing basis to ensure the continued effectiveness of the controls.	Functional	Subset Of	Security, Compliance & Resilience Controls Oversight	CPL-02	Mechanisms exist to provide a security, compliance and resilience controls oversight function that reports to the organization's executive leadership.	10		CAL2-3.12.3
3.12.3	N/A	Monitor security controls on an ongoing basis to ensure the continued effectiveness of the controls.	Functional	Intersects With	Threat Intelligence Program	THR-01	Mechanisms exist to implement a threat intelligence program that includes a cross-organization information-sharing capability that can influence the development of the system and security architectures, selection of security solutions, monitoring, threat hunting, response and recovery activities.	3		CAL2-3.12.3
3.12.3	N/A	Monitor security controls on an ongoing basis to ensure the continued effectiveness of the controls.	Functional	Intersects With	Threat Intelligence Feeds	THR-03	Mechanisms exist to maintain situational awareness of vulnerabilities and evolving threats by leveraging the knowledge of attacker tactics, techniques and procedures to facilitate the implementation of preventative and compensating controls.	5	updated in SCF release 2026.1	CAL2-3.12.3
3.12.4	N/A	Develop, document, and periodically update system security plans that describe system boundaries, system environments of operation, how security requirements are implemented, and the relationships with or connections to other systems.	Functional	Subset Of	Applied Security, Compliance and Resilience Controls with or connections to other systems.	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience	10		CAL2-3.12.4
3.12.4	N/A	Develop, document, and periodically update system security plans that describe system boundaries, system environments of operation, how security requirements are implemented, and the relationships with or connections to other systems.	Functional	Intersects With	Adequate Security for Sensitive / Regulated Data In Support of Contracts	IAO-03.2	Mechanisms exist to protect sensitive and/or regulated data that is collected, developed, received, transmitted, used or stored in support of the performance of a contract.	5		CAL2-3.12.4
3.13.1	N/A	Monitor, control, and protect communications (i.e., information transmitted or received by organizational systems) at the external boundaries and key internal boundaries of organizational systems.	Functional	Equal	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	10		SLC2-3.13.1
3.13.1	N/A	Monitor, control, and protect communications (i.e., information transmitted or received by organizational systems) at the external boundaries and key internal boundaries of organizational systems.	Functional	Intersects With	Guest Networks	NET-02.2	Mechanisms exist to implement and manage a secure guest network.	10	updated in SCF release 2026.1	SLC2-3.13.1
3.13.1	N/A	Monitor, control, and protect communications (i.e., information transmitted or received by organizational systems) at the external boundaries and key internal boundaries of organizational systems.	Functional	Equal	Boundary Protection	NET-03	Mechanisms exist to monitor and control communications at the external network boundary and at key internal boundaries within the network.	10		SLC2-3.13.1
3.13.2	N/A	Employ architectural designs, software development techniques, and systems engineering principles that promote effective information security within organizational systems.	Functional	Intersects With	Cloud Infrastructure Security Subnet	CLD-03	Mechanisms exist to host security-specific technologies in a dedicated subnet.	5		SLC2-3.13.2

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Reference	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	CHMC 2.0 Level 2
3.13.2	N/A	Employ architectural designs, software development techniques, and systems engineering principles that promote effective information security within organizational systems.	Functional	Subset Of	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	10		SLC2-3.13.2
3.13.2	N/A	Employ architectural designs, software development techniques, and systems engineering principles that promote effective information security within organizational systems.	Functional	Intersects With	Defense-In-Depth (DiD) Architecture	SEA-03	Mechanisms exist to implement security functions as a layered structure minimizing interactions between layers of the design and avoiding any dependence by lower layers on the functionality or correctness of higher layers.	3		SLC2-3.13.2
3.13.3	N/A	Separate user functionality from system management functionality.	Functional	Equal	Application Partitioning	SEA-03.2	Mechanisms exist to separate user functionality from system management functionality.	10		SLC2-3.13.3
3.13.4	N/A	Prevent unauthorized and unintended information transfer via shared system resources.	Functional	Equal	Information-In-Shared Resources	SEA-05	Mechanisms exist to prevent unauthorized and unintended information transfer via shared system resources.	10		SLC2-3.13.4
3.13.5	N/A	Implement subnetworks for publicly accessible system components that are physically or logically separated from internal networks.	Functional	Intersects With	Network Segmentation (macrosegmentation)	NET-06	Mechanisms exist to implement network segmentation within network architectures to isolate Technology Assets, Applications and/or Services (TAAS) from other network resources.	5		SLC2-3.13.5
3.13.6	N/A	Deny network communications traffic by default and allow network communications traffic by exception (i.e., deny all, permit by exception).	Functional	Equal	Deny Traffic by Default & Allow Traffic by Exception	NET-04.1	Mechanisms exist to configure firewall and router configurations to deny network traffic by default and allow network traffic by exception (e.g., deny all, permit by exception).	10		SLC2-3.13.6
3.13.7	N/A	Prevent remote devices from simultaneously establishing non-remote connections with organizational systems and communicating via some other connection to resources in external networks (i.e., split tunneling).	Functional	Equal	Split Tunneling	CFG-03.4	Mechanisms exist to prevent split tunneling for remote devices unless the split tunnel is securely provisioned using organization-defined safeguards.	10		SLC2-3.13.7
3.13.8	N/A	Implement cryptographic mechanisms to prevent unauthorized disclosure of CUI during transmission unless otherwise protected by alternative physical safeguards.	Functional	Equal	Alternate Physical Protection	CRY-01.1	Cryptographic mechanisms exist to prevent unauthorized disclosure of information as an alternative to physical safeguards.	10		SLC2-3.13.8
3.13.8	N/A	Implement cryptographic mechanisms to prevent unauthorized disclosure of CUI during transmission unless otherwise protected by alternative physical safeguards.	Functional	Intersects With	Transmission Confidentiality	CRY-03	Cryptographic mechanisms exist to protect the confidentiality of data being transmitted.	5		SLC2-3.13.8
3.13.9	N/A	Terminate network connections associated with communications sessions at the end of the sessions or after a defined period of inactivity.	Functional	Equal	Network Connection Termination	NET-07	Mechanisms exist to terminate network connections at the end of a session or after an organization-defined time period of inactivity.	10		SLC2-3.13.9
3.13.10	N/A	Establish and manage cryptographic keys for cryptography employed in organizational systems.	Functional	Intersects With	Public Key Infrastructure (PKI)	CRY-08	Mechanisms exist to securely implement an internal Public Key Infrastructure (PKI) infrastructure or obtain PKI services from a reputable PKI service provider.	5		SLC2-3.13.10
3.13.10	N/A	Establish and manage cryptographic keys for cryptography employed in organizational systems.	Functional	Intersects With	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	5		SLC2-3.13.10
3.13.11	N/A	Employ FIPS-validated cryptography when used to protect the confidentiality of CUI.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10		SLC2-3.13.11
3.13.12	N/A	Prohibit remote activation of collaborative computing devices and provide indication of devices in use to users present at the device.	Functional	Equal	Collaborative Computing Devices	END-14	Mechanisms exist to uplug or prohibit the remote activation of collaborative computing devices with the following exceptions: (1) Networked whiteboards; (2) Video teleconference cameras; and (3) Teleconference microphones.	10		SLC2-3.13.12
3.13.13	N/A	Control and monitor the use of mobile code.	Functional	Equal	Mobile Code	END-10	Mechanisms exist to address mobile code / operating system-independent applications.	10		SLC2-3.13.13
3.13.14	N/A	Control and monitor the use of Voice over Internet Protocol (VoIP) technologies.	Functional	Intersects With	Electronic Messaging	NET-13	Mechanisms exist to protect the confidentiality, integrity and availability of electronic messaging communications.	5		SLC2-3.13.14
3.13.15	N/A	Protect the authenticity of communications sessions.	Functional	Equal	Session Integrity	NET-09	Mechanisms exist to protect the authenticity and integrity of communications sessions.	10		SLC2-3.13.15
3.13.16	N/A	Protect the confidentiality of CUI at rest.	Functional	Intersects With	Encrypting Data At Rest	CRY-05	Cryptographic mechanisms exist to prevent unauthorized disclosure of data at rest.	8	updated in SCF release 2026.1	SLC2-3.13.16
3.13.16	N/A	Protect the confidentiality of CUI at rest.	Functional	Intersects With	Endpoint Protection Measures	END-02	Mechanisms exist to protect the confidentiality, integrity, availability and safety of endpoint devices.	8		SLC2-3.13.16
3.14.1	N/A	Identify, report, and correct system flaws in a timely manner.	Functional	Subset Of	Vulnerability & Patch Management Program (VPMPP)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	10		SLI2-3.14.1
3.14.1	N/A	Identify, report, and correct system flaws in a timely manner.	Functional	Intersects With	Vulnerability Remediation Process	VPM-02	Mechanisms exist to ensure that vulnerabilities are properly identified, tracked and remediated.	8	updated in SCF release 2026.1	SLI2-3.14.1
3.14.1	N/A	Identify, report, and correct system flaws in a timely manner.	Functional	Intersects With	Software & Firmware Patching	VPM-05	Mechanisms exist to conduct software patching for all deployed Technology Assets, Applications and/or Services (TAAS), including firmware.	8	updated in SCF release 2026.1	SLI2-3.14.1
3.14.2	N/A	Provide protection from malicious code at designated locations within organizational systems.	Functional	Subset Of	Endpoint Device Management (EDM)	END-01	Mechanisms exist to facilitate the implementation of Endpoint Device Management (EDM) controls.	10		SLI2-3.14.2
3.14.2	N/A	Provide protection from malicious code at designated locations within organizational systems.	Functional	Equal	Malicious Code Protection (anti-malware)	END-04	Mechanisms exist to utilize antim malware technologies to detect and eradicate malicious code.	10		SLI2-3.14.2
3.14.3	N/A	Monitor system security alerts and advisories and take action in response.	Functional	Equal	Security Event Monitoring	MON-01.8	Mechanisms exist to review event logs on an ongoing basis and escalate incidents in accordance with established timelines and procedures.	10		SLI2-3.14.3
3.14.3	N/A	Monitor system security alerts and advisories and take action in response.	Functional	Subset Of	Threat Intelligence Program	THR-01	Mechanisms exist to implement a threat intelligence program that includes a cross-organization information-sharing capability that can influence the development of the system and security architectures, selection of security solutions, monitoring, threat hunting, response and recovery activities.	10		SLI2-3.14.3
3.14.3	N/A	Monitor system security alerts and advisories and take action in response.	Functional	Intersects With	Threat Intelligence Feeds	THR-03	Mechanisms exist to maintain situational awareness of vulnerabilities and evolving threats by leveraging the knowledge of attacker tactics, techniques and procedures to facilitate the implementation of preventative and compensating controls.	5		SLI2-3.14.3
3.14.4	N/A	Update malicious code protection mechanisms when new releases are available.	Functional	Equal	Automatic Antimalware Signature Updates	END-04.1	Automated mechanisms exist to update antim malware technologies, including signature definitions.	10		SLI2-3.14.4
3.14.5	N/A	Perform periodic scans of organizational systems and real-time scans of files from external sources as files are downloaded, opened, or executed.	Functional	Equal	Always On Protection	END-04.7	Mechanisms exist to ensure that anti-malware technologies are continuously running in real-time and cannot be disabled or altered by non-privileged users, unless specifically authorized by management on a case-by-case basis for a limited time period.	10		SLI2-3.14.5
3.14.6	N/A	Monitor organizational systems, including inbound and outbound communications traffic, to detect attacks and indicators of potential attacks.	Functional	Subset Of	Continuous Monitoring	MON-01	Mechanisms exist to facilitate the implementation of enterprise-wide monitoring controls.	10	updated in SCF release 2026.1	SLI2-3.14.6
3.14.6	N/A	Monitor organizational systems, including inbound and outbound communications traffic, to detect attacks and indicators of potential attacks.	Functional	Intersects With	Inbound & Outbound Communications Traffic	MON-01.3	Mechanisms exist to continuously monitor inbound and outbound communications traffic for unusual or unauthorized activities or conditions.	8		SLI2-3.14.6
3.14.6	N/A	Monitor organizational systems, including inbound and outbound communications traffic, to detect attacks and indicators of potential attacks.	Functional	Intersects With	Network Intrusion Detection / Prevention Systems (NIDS / NIPS)	NET-08	Mechanisms exist to employ Network Intrusion Detection / Prevention Systems (NIDS/NIPS) to detect and/or prevent intrusions into the network.	8		SLI2-3.14.6
3.14.7	N/A	Identify unauthorized use of organizational systems.	Functional	Intersects With	Correlate Monitoring Information	MON-02.1	Automated mechanisms exist to correlate both technical and non-technical information from across the enterprise by a Security Incident Event Manager (SIEM) or similar automated tool, to enhance organization-wide situational awareness.	8		SLI2-3.14.7
3.14.7	N/A	Identify unauthorized use of organizational systems.	Functional	Intersects With	Monitoring for Indicators of Compromise (IOC)	MON-11.3	Automated mechanisms exist to identify and alert on Indicators of Compromise (IOC).	8	updated in SCF release 2026.1	SLI2-3.14.7
3.14.7	N/A	Identify unauthorized use of organizational systems.	Functional	Intersects With	Anomalous Behavior	MON-16	Mechanisms exist to utilize User & Entity Behavior Analytics (UEBA) and/or User Activity Monitoring (UAM) solutions to detect and respond to anomalous behavior that could indicate account compromise or other malicious activities.	8	updated in SCF release 2026.1	SLI2-3.14.7
3.14.7	N/A	Identify unauthorized use of organizational systems.	Functional	Intersects With	Indicators of Compromise (IOC)	IRO-03	Mechanisms exist to define specific Indicators of Compromise (IOC) to identify the signs of potential cybersecurity events.	8	updated in SCF release 2026.1	SLI2-3.14.7
NFO - AC-1	N/A	The organization: a. Develops, documents, and disseminates to [Assignment: organization-defined personnel or roles]: 1. An access control policy that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and 2. Procedures to facilitate the implementation of the access control policy and associated access controls; and b. Reviews and updates the current: 1. Access control policy [Assignment: organization-defined frequency]; and 2. Access control procedures [Assignment: organization-defined frequency].	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - AT-1	N/A	The organization: a. Develops, documents, and disseminates to [Assignment: organization-defined personnel or roles]: 1. A security awareness and training policy that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and 2. Procedures to facilitate the implementation of the security awareness and training policy and associated security awareness and training controls; and b. Reviews and updates the current: 1. Security awareness and training policy [Assignment: organization-defined frequency]; and 2. Security awareness and training procedures [Assignment: organization-defined frequency].	Functional	Subset Of	Security, Compliance & Resilience-Minded Workforce	SAT-01	Mechanisms exist to facilitate the implementation of security workforce development and awareness controls.	10	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - AT-4	N/A	The organization: a. Documents and monitors individual information system security training activities including basic security awareness training and specific information system security training; and b. Retains individual training records for [Assignment: organization-defined time period].	Functional	Intersects With	Security, Compliance & Resilience-Minded Workforce	SAT-04	Mechanisms exist to document, retain and monitor individual training activities, including: (1) Initial security, compliance and resilience awareness training; (2) Recurring awareness training; and (3) Technology Assets, Applications and/or Services (TAAS)-specific training.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Reference	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	CHMC 2.0 Level 2
NFO - AU-1	N/A	The organization: a. Develops, documents, and disseminates to [Assignment: organization-defined personnel or roles]: 1. An audit and accountability policy that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and 2. Procedures to facilitate the implementation of the audit and accountability policy and associated audit and accountability controls; and b. Reviews and updates the current: 1. Audit and accountability policy [Assignment: organization-defined frequency]; and 2. Audit and accountability procedures [Assignment: organization-defined frequency].	Functional	Subset Of	Continuous Monitoring	MON-01	Mechanisms exist to facilitate the implementation of enterprise-wide monitoring controls.	10	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - CA-1	N/A	The organization: a. Develops, documents, and disseminates to [Assignment: organization-defined personnel or roles]: 1. A security assessment and authorization policy that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and 2. Procedures to facilitate the implementation of the security assessment and authorization policy and associated security assessment and authorization controls; and b. Reviews and updates the current: 1. Security assessment and authorization policy [Assignment: organization-defined frequency]; and 2. Security assessment and authorization procedures [Assignment: organization-defined frequency].	Functional	Subset Of	Information Assurance (IA) Operations	IAO-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience assessment and authorization controls.	10	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - CA-2(1)	N/A	The organization employs assessors or assessment teams with [Assignment: organization-defined level of independence] to conduct security control assessments.	Functional	Intersects With	Assessor Independence	IAO-02.1	Mechanisms exist to ensure assessors or assessment teams have the appropriate independence to conduct security, compliance and/or resilience control assessments.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - CA-3	N/A	The organization: a. Authorizes connections from the information system to other information systems through the use of Interconnection Security Agreements; b. Documents, for each interconnection, the interface characteristics, security requirements, and the nature of the information communicated; and c. Reviews and updates Interconnection Security Agreements [Assignment: organization-defined frequency].	Functional	Intersects With	Interconnection Security Agreements (ISAs)	NET-05	Mechanisms exist to authorize connections from systems to other systems using Interconnection Security Agreements (ISAs), or similar methods, that document, for each interconnection: (1) Interface characteristics; (2) Security, compliance and resilience requirements; and; (3) The nature of the information communicated.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - CA-3(5)	N/A	The organization employs [Selection: allow-all, deny-by-exception; deny-all, permit-by-exception] policy for allowing [Assignment: organization-defined information systems] to connect to external information systems.	Functional	Intersects With	Deny Traffic by Default & Allow Traffic by Exception	NET-04.1	Mechanisms exist to configure firewall and router configurations to deny network traffic by default and allow network traffic by exception (e.g., deny all, permit by exception).	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - CA-7(1)	N/A	The organization employs assessors or assessment teams with [Assignment: organization-defined level of independence] to monitor the security controls in the information system on an ongoing basis.	Functional	Intersects With	Independent Assessors	CPL-03.1	Mechanisms exist to utilize independent assessors to evaluate security, compliance and resilience at planned intervals or when the Technology Asset, Application and/or Service (TAAS) undergoes significant changes.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - CA-9	N/A	The organization: a. Authorizes internal connections of [Assignment: organization-defined information system components or classes of components] to the information system; and b. Documents, for each internal connection, the interface characteristics, security requirements, and the nature of the information communicated.	Functional	Intersects With	Internal System Connections	NET-05.2	Mechanisms exist to control internal system connections through authorizing internal connections of systems and documenting, for each internal connection, the interface characteristics, security requirements and the nature of the information communicated.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - CM-1	N/A	The organization: a. Develops, documents, and disseminates to [Assignment: organization-defined personnel or roles]: 1. A configuration management policy that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and 2. Procedures to facilitate the implementation of the configuration management policy and associated configuration management controls; and b. Reviews and updates the current: 1. Configuration management policy [Assignment: organization-defined frequency]; and 2. Configuration management procedures [Assignment: organization-defined frequency].	Functional	Subset Of	Configuration Management Program	CFG-01	Mechanisms exist to facilitate the implementation of configuration management controls.	10	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - CM-2(1)	N/A	The organization reviews and updates the baseline configuration of the information system: (a) [Assignment: organization-defined frequency]; (b) When required due to [Assignment: organization-defined circumstances]; and (c) As an integral part of information system component installations and upgrades.	Functional	Intersects With	Reviews & Updates	CFG-02.1	Mechanisms exist to review and update baseline configurations: (1) At least annually; (2) When required due to soc or (3) As part of system component installations and upgrades.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - CM-2(7)	N/A	The organization: (a) Issues [Assignment: organization-defined information systems, system components, or devices] with [Assignment: organization-defined configurations] to individuals traveling to locations that the organization deems to be of significant risk; and (b) Applies [Assignment: organization-defined security safeguards] to the devices when the individuals return.	Functional	Intersects With	Configure Technology Assets, Applications and/or Services (TAAS) for High-Risk Areas	CFG-02.5	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) utilized in high-risk areas with more restrictive baseline configurations.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - CM-3(2)	N/A	The organization tests, validates, and documents changes to the information system before implementing the changes on the operational system.	Functional	Intersects With	Test, Validate & Document Changes	CHG-02.2	Mechanisms exist to appropriately test and document proposed changes in a non-production environment before changes are implemented in a production environment.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - CM-8(5)	N/A	The organization verifies that all components within the authorization boundary of the information system are not duplicated in other information system component inventories.	Functional	Intersects With	Component Duplication Avoidance	AST-02.3	Mechanisms exist to establish and maintain an authoritative source and repository to provide a trusted source and accountability for approved and implemented system components that prevents assets from being duplicated in other asset inventories.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - CM-9	N/A	The organization develops, documents, and implements a configuration management plan for the information system that: a. Addresses roles, responsibilities, and configuration management processes and procedures; b. Establishes a process for identifying configuration items throughout the system development life cycle and for managing the configuration of the configuration items; c. Defines the configuration items for the information system and places the configuration items under configuration management; and d. Protects the configuration management plan from unauthorized disclosure and modification.	Functional	Subset Of	Configuration Management Program	CFG-01	Mechanisms exist to facilitate the implementation of configuration management controls.	10	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - CM-9	N/A	The organization develops, documents, and implements a configuration management plan for the information system that: a. Addresses roles, responsibilities, and configuration management processes and procedures; b. Establishes a process for identifying configuration items throughout the system development life cycle and for managing the configuration of the configuration items; c. Defines the configuration items for the information system and places the configuration items under configuration management; and d. Protects the configuration management plan from unauthorized disclosure and modification.	Functional	Intersects With	Stakeholder Notification of Changes	CHG-05	Mechanisms exist to ensure stakeholders are made aware of and understand the impact of proposed changes.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - IA-1	N/A	The organization: a. Develops, documents, and disseminates to [Assignment: organization-defined personnel or roles]: 1. An identification and authentication policy that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and 2. Procedures to facilitate the implementation of the identification and authentication policy and associated identification and authentication controls; and b. Reviews and updates the current: 1. Identification and authentication policy [Assignment: organization-defined frequency]; and 2. Identification and authentication procedures [Assignment: organization-defined frequency].	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - IR-1	N/A	The organization: a. Develops, documents, and disseminates to [Assignment: organization-defined personnel or roles]: 1. An incident response policy that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and 2. Procedures to facilitate the implementation of the incident response policy and associated incident response controls; and b. Reviews and updates the current: 1. Incident response policy [Assignment: organization-defined frequency]; and 2. Incident response procedures [Assignment: organization-defined frequency].	Functional	Subset Of	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	10	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Reference	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	CHMHC 2.0 Level 2
NFO - IR-1	N/A	The organization: a. Develops, documents, and disseminates to [Assignment: organization-defined personnel or roles]: 1. An incident response policy that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and 2. Procedures to facilitate the implementation of the incident response policy and associated incident response controls; and b. Reviews and updates the current: 1. Incident response policy [Assignment: organization-defined frequency]; and 2. Incident response procedures [Assignment: organization-defined frequency].	Functional	Intersects With	IRP Update	IRO-04.2	Mechanisms exist to regularly review and modify incident response practices to incorporate lessons learned, business process changes and industry developments, as necessary.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E
NFO - IR-1	N/A	The organization: a. Develops, documents, and disseminates to [Assignment: organization-defined personnel or roles]: 1. An incident response policy that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and 2. Procedures to facilitate the implementation of the incident response policy and associated incident response controls; and b. Reviews and updates the current: 1. Incident response policy [Assignment: organization-defined frequency]; and 2. Incident response procedures [Assignment: organization-defined frequency].	Functional	Intersects With	Root Cause Analysis (RCA) & Lessons Learned	IRO-13	Mechanisms exist to incorporate lessons learned from analyzing and resolving cybersecurity and data protection incidents to reduce the likelihood or impact of future incidents.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E
NFO - IR-8	N/A	The organization: a. Develops an incident response plan that: 1. Provides the organization with a roadmap for implementing its incident response capability; 2. Describes the structure and organization of the incident response capability; 3. Provides a high-level approach for how the incident response capability fits into the overall organization; 4. Meets the unique requirements of the organization, which relate to mission, size, structure, and functions; 5. Defines reportable incidents; 6. Provides metrics for measuring the incident response capability within the organization; 7. Defines the resources and management support needed to effectively maintain and mature an incident response capability; and 8. Is reviewed and approved by [Assignment: organization-defined personnel or roles]; b. Distributes copies of the incident response plan to [Assignment: organization-defined incident response personnel (identified by name and/or by role) and organizational elements]; c. Reviews the incident response plan [Assignment: organization-defined frequency]; d. Updates the incident response plan to address system/organizational changes or problems encountered during plan implementation, execution, or testing; e. Communicates incident response plan changes to [Assignment: organization-defined incident response personnel (identified by name and/or by role) and organizational elements]; and f. Protects the incident response plan from unauthorized disclosure and modification.	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E
NFO - MA-1	N/A	The organization: a. Develops, documents, and disseminates to [Assignment: organization-defined personnel or roles]: 1. A system maintenance policy that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and 2. Procedures to facilitate the implementation of the system maintenance policy and associated system maintenance controls; and b. Reviews and updates the current: 1. System maintenance policy [Assignment: organization-defined frequency]; and 2. System maintenance procedures [Assignment: organization-defined frequency].	Functional	Subset Of	Maintenance Operations	MNT-01	Mechanisms exist to develop, disseminate, review & update procedures to facilitate the implementation of maintenance controls across the enterprise.	10	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E
NFO - MA-6(2)	N/A	The organization documents in the security plan for the information system, the policies and procedures for the establishment and use of nonlocal maintenance and diagnostic connections.	Functional	Intersects With	Remote Maintenance Notifications	MNT-05.2	Mechanisms exist to require maintenance personnel to notify affected stakeholders when remote, non-local maintenance is planned (e.g., downtime).	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E
NFO - MP-1	N/A	The organization: a. Develops, documents, and disseminates to [Assignment: organization-defined personnel or roles]: 1. A media protection policy that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and 2. Procedures to facilitate the implementation of the media protection policy and associated media protection controls; and b. Reviews and updates the current: 1. Media protection policy [Assignment: organization-defined frequency]; and 2. Media protection procedures [Assignment: organization-defined frequency].	Functional	Intersects With	Security of Assets & Media	AST-05	Mechanisms exist to maintain strict control over Technology Assets, Applications, Services and/or Data (TAASD) to preserve confidentiality and integrity.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E
NFO - MP-1	N/A	The organization: a. Develops, documents, and disseminates to [Assignment: organization-defined personnel or roles]: 1. A media protection policy that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and 2. Procedures to facilitate the implementation of the media protection policy and associated media protection controls; and b. Reviews and updates the current: 1. Media protection policy [Assignment: organization-defined frequency]; and 2. Media protection procedures [Assignment: organization-defined frequency].	Functional	Subset Of	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	10	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E
NFO - PE-1	N/A	The organization: a. Develops, documents, and disseminates to [Assignment: organization-defined personnel or roles]: 1. A physical and environmental protection policy that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and 2. Procedures to facilitate the implementation of the physical and environmental protection policy and associated physical and environmental protection controls; and b. Reviews and updates the current: 1. Physical and environmental protection policy [Assignment: organization-defined frequency]; and 2. Physical and environmental protection procedures [Assignment: organization-defined frequency].	Functional	Subset Of	Physical & Environmental Protections	PES-01	Mechanisms exist to facilitate the operation of physical and environmental protection controls.	10	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E
NFO - PE-6(1)	N/A	The organization monitors physical intrusion alarms and surveillance equipment.	Functional	Intersects With	Intrusion Alarms / Surveillance Equipment	PES-05.1	Physical access control mechanisms exist to monitor physical intrusion alarms and surveillance equipment.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E
NFO - PE-6	N/A	The organization: a. Maintains visitor access records to the facility where the information system resides for [Assignment: organization-defined time period]; and b. Reviews visitor access records [Assignment: organization-defined frequency].	Functional	Intersects With	Physical Access Logs	PES-03.3	Physical access control mechanisms generate a log entry for each access attempt through controlled ingress and egress points.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E
NFO - PE-16	N/A	The organization authorizes, monitors, and controls [Assignment: organization-defined types of information system components] entering and exiting the facility and maintains records of those items.	Functional	Intersects With	Delivery & Removal	PES-10	Physical security mechanisms exist to isolate information processing facilities from points such as delivery and loading areas and other points to avoid unauthorized access.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E
NFO - PL-1	N/A	The organization: a. Develops, documents, and disseminates to [Assignment: organization-defined personnel or roles]: 1. A security planning policy that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and 2. Procedures to facilitate the implementation of the security planning policy and associated security planning controls; and b. Reviews and updates the current: 1. Security planning policy [Assignment: organization-defined frequency]; and 2. Security planning procedures [Assignment: organization-defined frequency].	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Reference	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	CHMC 2.0 Level 2
NFO - PL-1	N/A	The organization: a. Develops, documents, and disseminates to [Assignment: organization-defined personnel or roles]: 1. A security planning policy that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and 2. Procedures to facilitate the implementation of the security planning policy and associated security planning controls; and b. Reviews and updates the current: 1. Security planning policy [Assignment: organization-defined frequency]; and 2. Security planning procedures [Assignment: organization-defined frequency].	Functional	Subset Of	Security, Compliance & Resilience Protection Portfolio Management	PRR-01	Mechanisms exist to facilitate the implementation of resource planning controls that provide a portfolio management approach to achieve security, compliance and resilience objectives.	10	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E
NFO - PL-2(3)	N/A	The organization plans and coordinates security-related activities affecting the information system with [Assignment: organization-defined individuals or groups] before conducting such activities in order to reduce the impact on other organizational entities.	Functional	Intersects With	Plan / Coordinate with Other Organizational Entities	IAQ-03.1	Mechanisms exist to plan and coordinate Information Assurance Program (IAP) activities with affected stakeholders before conducting such activities in order to reduce the potential impact on operations.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E
NFO - PL-4	N/A	The organization: a. Establishes and makes readily available to individuals requiring access to the information system, the rules that describe their responsibilities and expected behavior with regard to information and information system usage; b. Receives a signed acknowledgment from such individuals, indicating that they have read, understand, and agree to abide by the rules of behavior, before authorizing access to information and the information system; c. Reviews and updates the rules of behavior [Assignment: organization-defined frequency]; and d. Requires individuals who have signed a previous version of the rules of behavior to read and re-sign when the rules of behavior are revised/updated.	Functional	Intersects With	Terms of Employment	HRS-05	Mechanisms exist to require all employees and contractors to apply cybersecurity and data protection principles in their daily work to enable secure, compliant and resilient capabilities.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E
NFO - PL-4	N/A	The organization: a. Establishes and makes readily available to individuals requiring access to the information system, the rules that describe their responsibilities and expected behavior with regard to information and information system usage; b. Receives a signed acknowledgment from such individuals, indicating that they have read, understand, and agree to abide by the rules of behavior, before authorizing access to information and the information system; c. Reviews and updates the rules of behavior [Assignment: organization-defined frequency]; and d. Requires individuals who have signed a previous version of the rules of behavior to read and re-sign when the rules of behavior are revised/updated.	Functional	Intersects With	Rules of Behavior	HRS-05.1	Mechanisms exist to define acceptable and unacceptable rules of behavior for the use of technologies, including consequences for unacceptable behavior.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E
NFO - PL-4(1)	N/A	The organization includes in the rules of behavior, explicit restrictions on the use of social media/networking sites and posting organizational information on public websites.	Functional	Intersects With	Social Media & Social Networking Restrictions	HRS-05.2	Mechanisms exist to define rules of behavior that contain explicit restrictions on the use of social media and networking sites, posting information on commercial websites and sharing account information.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E
NFO - PL-8	N/A	The organization: a. Develops an information security architecture for the information system that: 1. Describes the overall philosophy, requirements, and approach to be taken with regard to protecting the confidentiality, integrity, and availability of organizational information; 2. Describes how the information security architecture is integrated into and supports the enterprise architecture; and 3. Describes any information security assumptions about, and dependencies on, external services; b. Reviews and updates the information security architecture [Assignment: organization-defined frequency] to reflect updates in the enterprise architecture; and c. Ensures that planned information security architecture changes are reflected in the security plan, the security Concept of Operations (CONOPS), and organizational procurements/acquisitions.	Functional	Intersects With	Alignment With Enterprise Architecture	SEA-02	Mechanisms exist to develop an enterprise architecture, aligned with industry-recognized leading practices, with consideration for security, compliance and resilience principles that address risk to organizational operations, assets, individuals and other organizations.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E
NFO-PL-8	N/A	The organization: a. Develops an information security architecture for the information system that: 1. Describes the overall philosophy, requirements, and approach to be taken with regard to protecting the confidentiality, integrity, and availability of organizational information; 2. Describes how the information security architecture is integrated into and supports the enterprise architecture; and 3. Describes any information security assumptions about, and dependencies on, external services; b. Reviews and updates the information security architecture [Assignment: organization-defined frequency] to reflect updates in the enterprise architecture; and c. Ensures that planned information security architecture changes are reflected in the security plan, the security Concept of Operations (CONOPS), and organizational procurements/acquisitions.	Functional	Subset Of	Cloud Services	CLD-01	Mechanisms exist to facilitate the implementation of cloud management controls to ensure cloud instances are secure and in-line with industry practices.	10	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E
NFO-PL-8	N/A	The organization: a. Develops an information security architecture for the information system that: 1. Describes the overall philosophy, requirements, and approach to be taken with regard to protecting the confidentiality, integrity, and availability of organizational information; 2. Describes how the information security architecture is integrated into and supports the enterprise architecture; and 3. Describes any information security assumptions about, and dependencies on, external services; b. Reviews and updates the information security architecture [Assignment: organization-defined frequency] to reflect updates in the enterprise architecture; and c. Ensures that planned information security architecture changes are reflected in the security plan, the security Concept of Operations (CONOPS), and organizational procurements/acquisitions.	Functional	Intersects With	Cloud Security Architecture	CLD-02	Mechanisms exist to ensure the cloud security architecture supports the organization's technology strategy to securely design, configure and maintain cloud employments.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E
NFO-PL-8	N/A	The organization: a. Develops an information security architecture for the information system that: 1. Describes the overall philosophy, requirements, and approach to be taken with regard to protecting the confidentiality, integrity, and availability of organizational information; 2. Describes how the information security architecture is integrated into and supports the enterprise architecture; and 3. Describes any information security assumptions about, and dependencies on, external services; b. Reviews and updates the information security architecture [Assignment: organization-defined frequency] to reflect updates in the enterprise architecture; and c. Ensures that planned information security architecture changes are reflected in the security plan, the security Concept of Operations (CONOPS), and organizational procurements/acquisitions.	Functional	Intersects With	Cloud Infrastructure Security Subnet	CLD-03	Mechanisms exist to host security-specific technologies in a dedicated subnet.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E
NFO - PS-1	N/A	The organization: a. Develops, documents, and disseminates to [Assignment: organization-defined personnel or roles]: 1. A personnel security policy that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and 2. Procedures to facilitate the implementation of the personnel security policy and associated personnel security controls; and b. Reviews and updates the current: 1. Personnel security policy [Assignment: organization-defined frequency]; and 2. Personnel security procedures [Assignment: organization-defined frequency].	Functional	Subset Of	Human Resources Security Management	HRS-01	Mechanisms exist to facilitate the implementation of personnel security controls.	10	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E
NFO - PS-6	N/A	The organization: a. Develops and documents access agreements for organizational information systems; b. Reviews and updates the access agreements [Assignment: organization-defined frequency]; and c. Ensures that individuals requiring access to organizational information and information systems: 1. Sign appropriate access agreements prior to being granted access; and 2. Re-sign access agreements to maintain access to organizational information systems when access agreements have been updated or [Assignment: organization-defined frequency].	Functional	Intersects With	Access Agreements	HRS-06	Mechanisms exist to require internal and third-party users to sign appropriate access agreements prior to being granted access.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	CMHC 2.0 Level 2
NFO - PS-7	N/A	The organization: a. Establishes personnel security requirements including security roles and responsibilities for third-party providers; b. Requires third-party providers to comply with personnel security policies and procedures established by the organization; c. Documents personnel security requirements; d. Requires third-party providers to notify (Assignment: organization-defined personnel or roles) of any personnel transfers or terminations of third-party personnel who possess organizational credentials and/or badges, or who have information system privileges within (Assignment: organization-defined time period); and e. Monitors provider compliance.	Functional	Intersects With	Third-Party Personnel	HRS-10	Mechanisms exist to govern third-party personnel by reviewing and monitoring third-party security, compliance and/or resilience roles and responsibilities.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - PS-8	N/A	The organization: a. Employs a formal sanctions process for individuals failing to comply with established information security policies and procedures; and b. Notifies (Assignment: organization-defined personnel or roles) within (Assignment: organization-defined time period) when a formal employee sanctions process is initiated, identifying the individual sanctioned and the reason for the sanction.	Functional	Intersects With	Personnel Sanctions	HRS-07	Mechanisms exist to sanction personnel failing to comply with established security policies, standards and procedures.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - RA-1	N/A	The organization: a. Develops, documents, and disseminates to (Assignment: organization-defined personnel or roles): 1. A risk assessment policy that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and 2. Procedures to facilitate the implementation of the risk assessment policy and associated risk assessment controls; and b. Reviews and updates the current: 1. Risk assessment policy (Assignment: organization-defined frequency); and 2. Risk assessment procedures (Assignment: organization-defined frequency).	Functional	Subset Of	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with: (1) The organization's Enterprise Risk Management (ERM); and (2) Industry-recognized cybersecurity risk management practices.	10	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - RA-5(1)	N/A	The organization employs vulnerability scanning tools that include the capability to readily update the information system vulnerabilities to be scanned.	Functional	Intersects With	Update Tool Capability	VPN-06.1	Mechanisms exist to update vulnerability scanning tools.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - RA-5(2)	N/A	The organization updates the information system vulnerabilities scanned (Selection (one or more): (Assignment: organization-defined frequency); prior to a new scan; when new vulnerabilities are identified and reported).	Functional	Intersects With	Update Tool Capability	VPN-06.1	Mechanisms exist to update vulnerability scanning tools.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - SA-1	N/A	The organization: a. Develops, documents, and disseminates to (Assignment: organization-defined personnel or roles): 1. A system and services acquisition policy that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and 2. Procedures to facilitate the implementation of the system and services acquisition policy and associated system and services acquisition controls; and b. Reviews and updates the current: 1. System and services acquisition policy (Assignment: organization-defined frequency); and 2. System and services acquisition procedures (Assignment: organization-defined frequency).	Functional	Intersects With	Secure Software Development Practices (SSDP)	TDA-06	Mechanisms exist to develop applications based on Secure Software Development Practices (SSDP).	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - SA-2	N/A	The organization: a. Determines information security requirements for the information system or information system service in mission/business process planning; b. Determines, documents, and allocates the resources required to protect the information system or information system service as part of its capital planning and investment control process; and c. Establishes a discrete line item for information security in organizational programming and budgeting documentation.	Functional	Intersects With	Allocation of Resources	PRM-03	Mechanisms exist to identify and allocate resources for management, operational, technical and data protection requirements within business process planning for projects / initiatives.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - SA-3	N/A	The organization: a. Manages the information system using (Assignment: organization-defined system development life cycle) that incorporates information security considerations; b. Defines and documents information security roles and responsibilities throughout the system development life cycle; c. Identifies individuals having information security roles and responsibilities; and d. Integrates the organizational information security risk management process into system development life cycle activities.	Functional	Intersects With	Secure Development Life Cycle (SDLC) Management	PRM-07	Mechanisms exist to ensure changes to Technology Assets, Applications and/or Services (TASs) within the Secure Development Life Cycle (SDLC) are controlled through formal change control procedures.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - SA-3	N/A	The organization: a. Manages the information system using (Assignment: organization-defined system development life cycle) that incorporates information security considerations; b. Defines and documents information security roles and responsibilities throughout the system development life cycle; c. Identifies individuals having information security roles and responsibilities; and d. Integrates the organizational information security risk management process into system development life cycle activities.	Functional	Intersects With	Predictable Failure Analysis	SEA-07	Mechanisms exist to determine the Mean Time to Failure (MTTF) for system components in specific environments of operation.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - SA-3	N/A	The organization: a. Manages the information system using (Assignment: organization-defined system development life cycle) that incorporates information security considerations; b. Defines and documents information security roles and responsibilities throughout the system development life cycle; c. Identifies individuals having information security roles and responsibilities; and d. Integrates the organizational information security risk management process into system development life cycle activities.	Functional	Intersects With	Technology Lifecycle Management	SEA-07.1	Mechanisms exist to manage the usable lifecycles of Technology Assets, Applications and/or Services (TASs).	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - SA-4	N/A	The organization includes the following requirements, descriptions, and criteria, explicitly or by reference, in the acquisition contract for the information system, system component, or information system service in accordance with applicable federal laws, Executive Orders, directives, policies, regulations, standards, guidelines, and organizational mission/business needs: a. Security functional requirements; b. Security strength requirements; c. Security assurance requirements; d. Security-related documentation requirements; e. Requirements for protecting security-related documentation; f. Description of the information system development environment and environment in which the system is intended to operate; and g. Acceptance criteria.	Functional	Subset Of	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	10	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - SA-4	N/A	The organization includes the following requirements, descriptions, and criteria, explicitly or by reference, in the acquisition contract for the information system, system component, or information system service in accordance with applicable federal laws, Executive Orders, directives, policies, regulations, standards, guidelines, and organizational mission/business needs: a. Security functional requirements; b. Security strength requirements; c. Security assurance requirements; d. Security-related documentation requirements; e. Requirements for protecting security-related documentation; f. Description of the information system development environment and environment in which the system is intended to operate; and g. Acceptance criteria.	Functional	Intersects With	Minimum Viable Product (MVP) Security Requirements	TDA-02	Mechanisms exist to design, develop and produce Technology Assets, Applications and/or Services (TASs) in such a way that risk-based technical and functional specifications ensure Minimum Viable Product (MVP) criteria establish an appropriate level of security and resiliency based on applicable risks and threats.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E
NFO - SA-4	N/A	The organization includes the following requirements, descriptions, and criteria, explicitly or by reference, in the acquisition contract for the information system, system component, or information system service in accordance with applicable federal laws, Executive Orders, directives, policies, regulations, standards, guidelines, and organizational mission/business needs: a. Security functional requirements; b. Security strength requirements; c. Security assurance requirements; d. Security-related documentation requirements; e. Requirements for protecting security-related documentation; f. Description of the information system development environment and environment in which the system is intended to operate; and g. Acceptance criteria.	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 RA.	NFO - NIST 800-171 App E

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Reference	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	CHMC 2.0 Level 2
NFO-SA-4	N/A	The organization includes the following requirements, descriptions, and criteria, explicitly or by reference, in the acquisition contract for the information system, system component, or information system service in accordance with applicable federal laws, Executive Orders, directives, policies, regulations, standards, guidelines, and organizational mission/business needs: a. Security functional requirements; b. Security strength requirements; c. Security assurance requirements; d. Security-related documentation requirements; e. Requirements for protecting security-related documentation; f. Description of the information system development environment and environment in which the system is intended to operate; and g. Acceptance criteria.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO-NIST800-171 App E
NFO-SA-4(1)	N/A	The organization requires the developer of the information system, system component, or information system service to provide a description of the functional properties of the security controls to be employed.	Functional	Intersects With	Functional Properties	TDA-04.1	Mechanisms exist to require software developers to provide information describing the functional properties of the security, compliance and resilience controls to be utilized within Technology Assets, Applications and/or Services (TAAS) in sufficient detail to permit analysis and testing of the controls.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO-NIST800-171 App E
NFO-SA-4(2)	N/A	The organization requires the developer of the information system, system component, or information system service to provide design and implementation information for the security controls to be employed that includes: [Selection (one or more): security-relevant external system interfaces; high-level design; low-level design; source code or hardware schematics; [Assignment: organization-defined design/implementation information]] at [Assignment: organization-defined level of detail].	Functional	Intersects With	Functional Properties	TDA-04.1	Mechanisms exist to require software developers to provide information describing the functional properties of the security, compliance and resilience controls to be utilized within Technology Assets, Applications and/or Services (TAAS) in sufficient detail to permit analysis and testing of the controls.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO-NIST800-171 App E
NFO-SA-4(9)	N/A	The organization requires the developer of the information system, system component, or information system service to identify early in the system development life cycle, the functions, ports, protocols, and services intended for organizational use.	Functional	Intersects With	Ports, Protocols & Services in Use	TDA-02.1	Mechanisms exist to require the developers of Technology Assets, Applications and/or Services (TAAS) to identify early in the Secure Development Life Cycle (SDLC), the functions, ports, protocols and services intended for use.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO-NIST800-171 App E
NFO-SA-4(10)	N/A	The organization employs only information technology products on the FIPS 201 approved products list for Personal Identity Verification (PIV) capability implemented within organizational information systems.	Functional	Intersects With	Information Assurance Enabled Products	TDA-02.2	Mechanisms exist to limit the use of commercially-provided Information Assurance (IA) and IA-enabled IT products to those products that have been successfully evaluated against a National Information Assurance partnership (NIAP)-approved Protection Profile or the cryptographic module is FIPS-validated or NSA-approved.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO-NIST800-171 App E
NFO-SA-5	N/A	The organization: a. Obtains administrator documentation for the information system, system component, or information system service that describes: 1. Secure configuration, installation, and operation of the system, component, or service; 2. Effective use and maintenance of security functions/mechanisms; and 3. Known vulnerabilities regarding configuration and use of administrative (i.e., privileged) functions; b. Obtains user documentation for the information system, system component, or information system service that describes: 1. User-accessible security functions/mechanisms and how to effectively use those security functions/mechanisms; 2. Methods for user interaction, which enables individuals to use the system, component, or service in a more secure manner; and 3. User responsibilities in maintaining the security of the system, component, or service; c. Documents attempts to obtain information system, system component, or information system service documentation when such documentation is either unavailable or nonexistent and takes [Assignment: organization-defined action] in response; d. Protects documentation as required, in accordance with the risk management strategy; and e. Distributes documentation to [Assignment: organization-defined personnel or roles].	Functional	Intersects With	Documentation Requirements	TDA-04	Mechanisms exist to obtain, protect and distribute administrator documentation for Technology Assets, Applications and/or Services (TAAS) that describe: (1) Secure configuration, installation and operation of the TAAS; (2) Effective use and maintenance of security features/functions; and (3) Known vulnerabilities regarding configuration and use of administrative (e.g., privileged) functions.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO-NIST800-171 App E
NFO-SA-9	N/A	The organization: a. Requires that providers of external information system services comply with organizational information security requirements and employ [Assignment: organization-defined security controls] in accordance with applicable federal laws, Executive Orders, directives, policies, regulations, standards, and guidance; b. Defines and documents government oversight and user roles and responsibilities with regard to external information system services; and c. Employs [Assignment: organization-defined processes, methods, and techniques] to monitor security control compliance by external service providers on an ongoing basis.	Functional	Intersects With	Third-Party Services	TPM-04	Mechanisms exist to mitigate the risks associated with third-party access to the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO-NIST800-171 App E
NFO-SA-9(2)	N/A	The organization requires providers of [Assignment: organization-defined external information system services] to identify the functions, ports, protocols, and other services required for the use of such services.	Functional	Intersects With	External Connectivity Requirements - Identification of Ports, Protocols & Services	TPM-04.2	Mechanisms exist to require External Service Providers (ESPs) to identify and document the business need for ports, protocols and other services it requires to operate its Technology Assets, Applications and/or Services (TAAS).	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO-NIST800-171 App E
NFO-SA-10	N/A	The organization requires the developer of the information system, system component, or information system service to: a. Perform configuration management during system, component, or service [Selection (one or more): design; development; implementation; operation]; b. Document, manage, and control the integrity of changes to [Assignment: organization-defined configuration items under configuration management]; c. Implement only organization-approved changes to the system, component, or service; d. Document approved changes to the system, component, or service and the potential security impacts of such changes; and e. Track security flaws and flaw resolution within the system, component, or service and report findings to [Assignment: organization-defined personnel].	Functional	Intersects With	Developer Configuration Management	TDA-14	Mechanisms exist to require system developers/integrators to perform configuration management during system design, development, implementation and operation.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO-NIST800-171 App E
NFO-SA-11	N/A	The organization requires the developer of the information system, system component, or information system service to: a. Create and implement a security assessment plan; b. Perform [Selection (one or more): unit; integration; system; regression] testing/evaluation at [Assignment: organization-defined depth and confidence level]; c. Produce evidence of the execution of the security assessment plan and the results of the security testing/evaluation; d. Implement a verifiable flaw remediation process; and e. Correct flaws identified during security testing/evaluation.	Functional	Intersects With	Security, Compliance & Resilience Testing Throughout Development	TDA-09	Mechanisms exist to require system developers/integrators consult with security, compliance and/or resilience personnel to: (1) Create and implement a Security Testing and Evaluation (ST&E) plan, or similar capability; (2) Implement a verifiable flaw remediation process to correct weaknesses and deficiencies identified during the control testing and evaluation process; and (3) Document the results.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO-NIST800-171 App E
NFO-SC-1	N/A	The organization: a. Develops, documents, and disseminates to [Assignment: organization-defined personnel or roles]: 1. A system and communications protection policy that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and 2. Procedures to facilitate the implementation of the system and communications protection policy and associated system and communications protection controls; and b. Reviews and updates the current: 1. System and communications protection policy [Assignment: organization-defined frequency]; and 2. System and communications protection procedures [Assignment: organization-defined frequency].	Functional	Subset Of	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	10	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO-NIST800-171 App E
NFO-SC-7(3)	N/A	The organization limits the number of external network connections to the information system.	Functional	Intersects With	Limit Network Connections	NET-03.1	Mechanisms exist to limit the number of concurrent external network connections to its Technology Assets, Applications and/or Services (TAAS).	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO-NIST800-171 App E
NFO-SC-7(4)	N/A	The organization: (a) Implements a managed interface for each external telecommunication service; (b) Establishes a traffic flow policy for each managed interface; (c) Protects the confidentiality and integrity of the information being transmitted across each interface; (d) Documents each exception to the traffic flow policy with a supporting mission/business need and duration of that need; and (e) Reviews exceptions to the traffic flow policy [Assignment: organization-defined frequency] and removes exceptions that are no longer supported by an explicit mission/business need.	Functional	Intersects With	External Telecommunications Services	NET-03.2	Mechanisms exist to maintain a managed interface for each external telecommunication service that protects the confidentiality and integrity of the information being transmitted across each interface.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO-NIST800-171 App E
NFO-SC-20	N/A	The information system: a. Provides additional data origin authentication and integrity verification artifacts along with the authoritative name resolution data the system returns in response to external name/address resolution queries; and b. Provides the means to indicate the security status of child zones and (if the child supports secure resolution services) to enable verification of a chain of trust among parent and child domains, when operating as part of a distributed, hierarchical namespace.	Functional	Intersects With	Domain Name Service (DNS) Resolution	NET-10	Mechanisms exist to ensure Domain Name Service (DNS) resolution is designed, implemented and managed to protect the security of name / address resolution.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO-NIST800-171 App E
NFO-SC-21	N/A	The information system requests and performs data origin authentication and data integrity verification on the name/address resolution responses the system receives from authoritative sources.	Functional	Intersects With	Secure Name / Address Resolution Service (Recursive or Caching Resolver)	NET-10.2	Mechanisms exist to perform data origin authentication and data integrity verification on the Domain Name Service (DNS) resolution responses received from authoritative sources when requested by client systems.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO-NIST800-171 App E
NFO-SC-22	N/A	The information systems that collectively provide name/address resolution services for an organization are fault-tolerant and implement internal/external role separation.	Functional	Intersects With	Architecture & Provisioning for Name / Address Resolution Service	NET-10.1	Mechanisms exist to ensure systems that collectively provide Domain Name Service (DNS) resolution service are fault-tolerant and implement internal/external role separation.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO-NIST800-171 App E
NFO-SC-39	N/A	The information system maintains a separate execution domain for each executing process.	Functional	Intersects With	Process Isolation	SEA-04	Mechanisms exist to implement a separate execution domain for each executing process.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO-NIST800-171 App E

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Relationship	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	CMHC 2.0 Level 2
NFO - SI-1	N/A	The organization: a. Develops, documents, and disseminates to [Assignment: organization-defined personnel or roles]: 1. A system and information integrity policy that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and 2. Procedures to facilitate the implementation of the system and information integrity policy and associated system and information integrity controls; and b. Reviews and updates the current: 1. System and information integrity policy [Assignment: organization-defined frequency]; and 2. System and information integrity procedures [Assignment: organization-defined frequency].	Functional	Intersects With	Transmission Integrity	CRY-04	Cryptographic mechanisms exist to protect the integrity of data being transmitted.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E
NFO - SI-4(S)	N/A	The information system alerts [Assignment: organization-defined personnel or roles] when the following indications of compromise or potential compromise occur [Assignment: organization-defined compromise indicators].	Functional	Subset Of	System Generated Alerts	MON-01.4	Mechanisms exist to generate, monitor, correlate and respond to alerts from physical, cybersecurity, data protection and supply chain activities to achieve integrated situational awareness.	10	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E
NFO - SI-16	N/A	The information system implements [Assignment: organization-defined security safeguards] to protect its memory from unauthorized code execution.	Functional	Intersects With	Memory Protection	SEA-10	Mechanisms exist to implement security safeguards to protect system memory from unauthorized code execution.	5	Non-Federal Organization (NFO) controls can be found in Appendix E of NIST SP 800-171 R2. NFO controls are sourced directly from NIST SP 800-53 R4.	NFO - NIST 800-171 App E